

Code-Sage AI Software Architecture Document For the AI-Powered Technical-Debt Analytics Dashboard

Version 1.1

Group 16 | Project ID 7 | CS3203 - Software Engineering Project
Mentor: Mr. Anju Chamantha
Date: 15th August 2026

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Revision History

Date	Version	Description	Author
09/Aug/2026	1.0	This document establishes the initial v1.0 architecture (4+1 views, data model, and quality attributes). Aligned with SRS v1.0.	Group 16
15/Aug/2026	1.1	Aligned with SRS v1.1. Sign-in becomes Asgardeo with GitHub federated, and the API service is named as the Backend-for-Frontend that holds the identity tokens; a new Section 6.4 sets out that exchange. Section 2 now names the architectural style and states why a set of independent services was not chosen. The scoring profile is corrected to six numbers, being five category weights and one trust slider. Prose that referred to SCAN and FILE_SCORE tables now uses the entities the data model actually defines. Security and performance tables gain the requirements added in SRS v1.1, and three empty table cells and the Section 1.5 section list were corrected.	Group 16

Individual Contributions

Index No.	Name	Contributions
230432G	Nethmini R.M.N.	Prepared and documented Introduction, Use-Case View, Implementation View, Deployment View, Reliability, Scalability, AI Model Quality.
230435T	Nethsara U.D.K.C.	Prepared and documented Architectural Representation, Logical View, Deployment View, Data View, Performance, Security, Privacy, Portability.
230451M	Pabasara H.H.J.	Prepared and documented Architectural Goals and Constraints, Process View, Size and Performance, Usability, Supportability, Maintainability.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Table of Contents

1.	Introduction	5
1.1	Purpose	5
1.2	Scope	5
1.3	Definitions, Acronyms, and Abbreviations	5
1.4	References	6
1.5	Overview	6
2.	Architectural Representation	7
3.	Architectural Goals and Constraints	8
4.	Use-Case View	9
4.1	Sign In	10
4.2	Connect Repository	11
4.3	Run Repository Scan	11
4.4	View Health Dashboard	12
4.5	Triage & Filter Findings	13
4.6	Select / Configure Scoring Profile	13
4.7	Browse Scan History	14
5.	Logical View	15
5.1	Overview	15
5.2	Architecturally Significant Design Packages	16
6.	Process View	22
6.1	The extraction boundary	25
6.2	Applying a scoring profile	27
6.3	The visibility floor	29
6.4	Signing in	30
7.	Deployment View	30
8.	Implementation View	33
8.1	Overview	33
8.2	Layers	33
8.2.1	Presentation Layer	34
8.2.2	Application Layer	34
8.2.3	Data Layer	34
8.2.4	External Systems	34
9.	Data View	35
10.	Size and Performance	38
11.	Performance Measurements	40

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

12.	Quality	40
12.1	Reliability	40
12.2	Performance	41
12.3	Security	41
12.4	Privacy	42
12.5	Usability	43
12.6	Maintainability	43
12.7	Supportability	43
12.8	Portability	43
12.9	Scalability	44
12.10	AI Model Quality	44

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

1. Introduction

1.1 Purpose

This document describes the software architecture of Code Sage AI, the AI-powered technical-debt analytics dashboard specified in the Software Requirements Specification. It uses the RUP "4+1" model, so the system is presented through five views - Use-Case, Logical, Process, Deployment and Implementation - together with a Data View, because the persistent schema in this system carries real architectural weight and leaving it out would hide a central decision.

The document has three audiences. The development team uses it to know which component owns which responsibility before writing code. The mentor and the evaluators use it to judge whether the design actually delivers what the SRS promises. Future maintainers use it to understand why the system is shaped this way, so that a later change does not quietly break an assumption the design depends on.

It should be read together with the SRS, which states what the system must do. This document states how the parts are arranged to do it. Where the two overlap, the SRS is the normative source, and this document refers back to the requirement by its identifier.

1.2 Scope

This document covers the architecture of the v1.0 release: a multi-tenant web application in which a user signs in through the Asgardeo identity provider, connects a public repository by pasting its URL, runs a scan on a chosen branch when they decide to, and reads a prioritised technical-debt dashboard built from the stored result. It covers all four parts of the system - the frontend, the backend API and its asynchronous workers, the machine-learning service, and the database.

Three limits are stated here because they shape several of the views that follow.

- Repository access in v1.0 is public repositories by URL only. Sign-in uses Asgardeo, which federates GitHub, and the analysis pipeline reads the repository through an ordinary git clone. Signing in and reading a repository are therefore two unrelated grants: the system never asks a user for repository permission, and never holds a GitHub token on their behalf. There is no GitHub App installation, no private-repository support and no webhook endpoint in v1.0. Those belong to later releases, and this document marks the points where they would attach (SRS FR-3, Table 3-21).

- **Scans are started by the user, never by an event.** There is no automatic or event-driven analysis in v1.0. A scan happens because a user asked for it (SRS FR-6).

- **Later-release concerns are out of scope.** Team management, role-based access control, private repositories and additional Git hosts are mentioned only where they affect a v1.0 decision - for example the tenant column that exists from day one so that multi-user workspaces can be added later without a migration (SRS FR-2, FR-23).

1.3 Definitions, Acronyms, and Abbreviations

The project keeps a single glossary in SRS Section 1.3, and that glossary is the authority. The terms used most often in this document are repeated below for the reader's convenience.

Table 1-1. Terms used most often in this document.

Term	Meaning in this document
Finding	One detected issue at a file:line:symbol, carrying a source, a category, a severity and a one-line reason. The atomic unit of output.
source	Which detector produced a finding. Exactly two values: rule or satd (SRS FR-8.2).
category	What kind of debt a finding is. Exactly five values: code-design, requirement, documentation, test and security (SRS FR-9.3).
Snapshot	The stored, immutable result of one scan, identified by repository, branch, commit SHA and time.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Term	Meaning in this document
Scoring profile	The five category weights plus the trust slider that turn stored findings into scores (SRS FR-20).
Visibility floor	The rule that a critical security finding stays visible no matter how the profile is set (SRS FR-24).
Workspace / tenant	The top-level owner of data. A project belongs to a workspace, not to a person.
RLS	PostgreSQL Row-Level Security, the mechanism used to keep tenants apart.
ML-1 / ML-2	The SATD comment classifier and the file-level bug-proneness risk model.
Asgardeo	The hosted identity provider. GitHub sign-in is federated inside it, so this system is a client of one provider rather than of each sign-in method (SRS FR-1).
BFF	Backend-for-Frontend. The browser talks only to this system's own API, and that API holds every external credential. The FastAPI service plays that role here (SRS SEC-17).
Session	A server-side record of one signed-in user. The browser holds only an opaque identifier for it, in an httpOnly cookie, so sign-out can revoke it (SRS SEC-10).

1.4 References

The documents referenced elsewhere in this SAD are listed below.

Table 1-2. Referenced documents.

#	Document	Where it is held
1	Software Requirements Specification, Code Sage AI v1.0. The normative source for every requirement identifier used in this document.	docs/Deliverables/Software_Requirements_Specification.docx
2	Change Request CR-001 - scoring model and finding UX (decisions D-CR1 to D-CR12).	docs/Change Requests/
3	Backend Analysis Engine design note.	docs/Project Management & Planning/
4	Release Roadmap and Frontend Prototype Plan.	docs/Project Management & Planning/
5	Project Proposal and Feasibility Report.	docs/Deliverables/
6	REST contract - the OpenAPI 3.1 document that is the single source of truth for every shape crossing the frontend and backend boundary (SRS SP-4). The frontend's TypeScript types are generated from it.	docs/api/openapi.yaml

1.5 Overview

The rest of the document is organized as follows.

Section 2 explains which architectural views are used and why. Section 3 lists the goals and constraints that actually shaped the design, each with its architectural consequence. Sections 4 to 8 present the five views: the use cases that exercise the architecture, the decomposition into subsystems and classes, the runtime behaviour of the processes, the physical deployment, and the layering of the codebase. Section 9 describes the persistent data model and the rule that separates stored facts from derived scores. Section 10 covers sizing and performance targets, Section 11 records the measurements to be taken during performance testing, and Section 12 explains how the architecture delivers each

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

quality attribute.

Figures are referenced by number throughout. Figures 1 to 10 carry the architecture itself, and Figures 1.1 to 1.7 expand the individual use cases of Figure 1. Each is cited in the text as "Figure n" and is described in the sentences that follow it.

2. Architectural Representation

CodeSage AI is a web-based software-as-a-service application designed for small scale agile software development teams to detect and prioritize technical debt in their code repositories hosted on GitHub. It uses a multi-tenant data architecture and each project, scan and finding belongs to a specific workspace. The initial version of the system limits each workspace to a single user. The system consists of a browser-based frontend, a backend API, asynchronous repository analyzing workers, offline trained machine-learning components and a database. The repository scans are initiated manually by users and executed in the background so that the user interface of the system remains responsive during the repository scan and analysis. The findings of the analysis are presented through an interactive dashboard that displays repository health information, historical analysis results and a prioritized Refactor-First list that shows the findings that should be addressed first.

This document uses multiple views to represent the architecture of the application to describe the structural, behavioral, runtime, deployment and implementation aspects of the system. It follows the 4+1 architectural view approach that consists of Use-Case View, Logical View, Process View, Deployment View and Implementation View. A separate Data View is included to represent the architectural decisions of the database that is used to store the persistent data of the application.

The architectural style is a modular monolith with an asynchronous worker and one extracted inference service. The API and the worker are built from one codebase and run from the same container image with different commands, so a change that spans a request handler and the pipeline it queues is one release rather than two. Inside that monolith four further styles are used, each for a specific requirement: the code is layered, so the presentation layer cannot reach the database; the scan pipeline is a pipe and filter arrangement of clone, extract, detect and finalize, so the cancellation check has well-defined places to sit; the API and its workers form a producer and competing-consumer pair over a broker, so concurrency is a deployment setting rather than a code change; and the write path is separated from the read path, so a scan stores facts and every score is derived when the dashboard is requested.

A set of independently deployed services was considered and rejected, for four reasons that hold regardless of team size. The domain is one bounded context: repository, branch, analysis attempt, snapshot and finding form a single joined graph that the dashboard reads in one query. The central correctness rule is a database transaction, because SRS DBR-22 requires a snapshot and all of its findings, metrics and predictions to be committed together or not at all; split across services that becomes a distributed transaction with compensating actions, and the half-written snapshot that SRS FR-6 forbids becomes a state the system can actually reach. Tenant isolation depends on PostgreSQL Row-Level Security, which is one mechanism over one database and becomes several separate arguments once the data is split. And the boundaries that would be drawn here follow workload rather than business capability, which is a reason to separate processes, not to separate services and their data.

The machine-learning service is the one process deployed separately, and it is not a service in that sense either: it owns no data and no business capability. It is extracted so that its unavailability is a designed mode rather than an exception, so that a retrained model can be replaced by swapping a mounted artefact, and so that the training dependencies stay out of the API image. Section 7 sets out the resulting deployment.

View	What it captures	Diagrams
Use-Case View	Describes the actors, external systems, use cases and relationships that represent architecturally	Use-case diagram, scenario tables (Figure 1)

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

	significant interactions with the system	
Logical View	Describes the static structure of the system, including its main subsystems, packages, domain classes, responsibilities, attributes and relationships	class diagram (Figures 3)
Process View	Describes the runtime behavior of the system. This includes the API process, asynchronous workers, task queue, machine-learning inference, database communication and the sequence of activities of repository scanning and profile application	Activity and sequence diagrams (Figures 4, 5, 6)
Deployment View	Describes the physical and container-level deployment of the system. This includes client services, application containers, worker containers, the Redis broker and the network connections	Deployment diagram (Figure 7)
Implementation View	Describes how the software is organized in the source code including applications, architectural layers, packages, modules, components, boundaries between the presentation, application and data layers.	Component and package diagrams (Figures 8, 9)
Data View	Describes the persistent data model, including entities, attributes, relationships, tenant ownership, immutable scan snapshots, and the distinction between stored analysis facts and scores calculated when results are retrieved.	ER diagram (Figure 10)

3. Architectural Goals and Constraints

Table 3-1. Architectural goals and their consequences.

#	Goal or constraint	What it forces in the architecture
G1	Secure multi-tenant architecture.	A workspace is a tenant. Workspace is protected by PostgreSQL Row-Level Security
G2	The UI must stay responsive during the scan.	Scans run on Celery workers behind a Redis broker, never inside the HTTP request. The API returns a scan ID immediately and the client polls for progress.
G3	Dashboard output should be low noise and explainable	Rule based thresholds and one line reason templates; Prioritized list for the findings

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

#	Goal or constraint	What it forces in the architecture
G4	Profile change does not require a complete re-scan	Scoring is done by backend engine at read time over stored findings. It does not perform a database write for each final dashboard outputs
G5	Severity never altered by users	Severity is assigned at development time and managed via config files. Users can only change scoring profiles
G6	Core features Should be developed first; Secondary features added top of existing core	Complete vertical slice of whole project scope will be developed first; Rule-based engine can work on its own. ML Services are delivered as separate services which can change without affecting core backend logic
G7	Free, containerized, independently scalable stack	Every component is delivered as Docker container. Workers scale horizontally to handle concurrent load.
G8	No credential the browser holds may be worth stealing.	Sign-in is completed by the API, not by the browser. The API is the Backend-for-Frontend: it performs the authorization-code exchange with Asgardeo, keeps the identity tokens in its own process and database, and returns an httpOnly session cookie that JavaScript cannot read. Sessions are server-side, so signing out revokes access on the next request (SRS SEC-10, SEC-17 to SEC-20).

Constraints. The technology stack is frozen: Next.js and Tailwind for the frontend; FastAPI, Celery and Redis for the backend; Python with scikit-learn, Tree-sitter, CK and PyDriller for metric extraction, analysis and ML; PostgreSQL for storage; Asgardeo for identity; Docker for deployment. Only supervised learning is used. Models are trained offline on public datasets and loaded at runtime as versioned artifacts.

4. Use-Case View

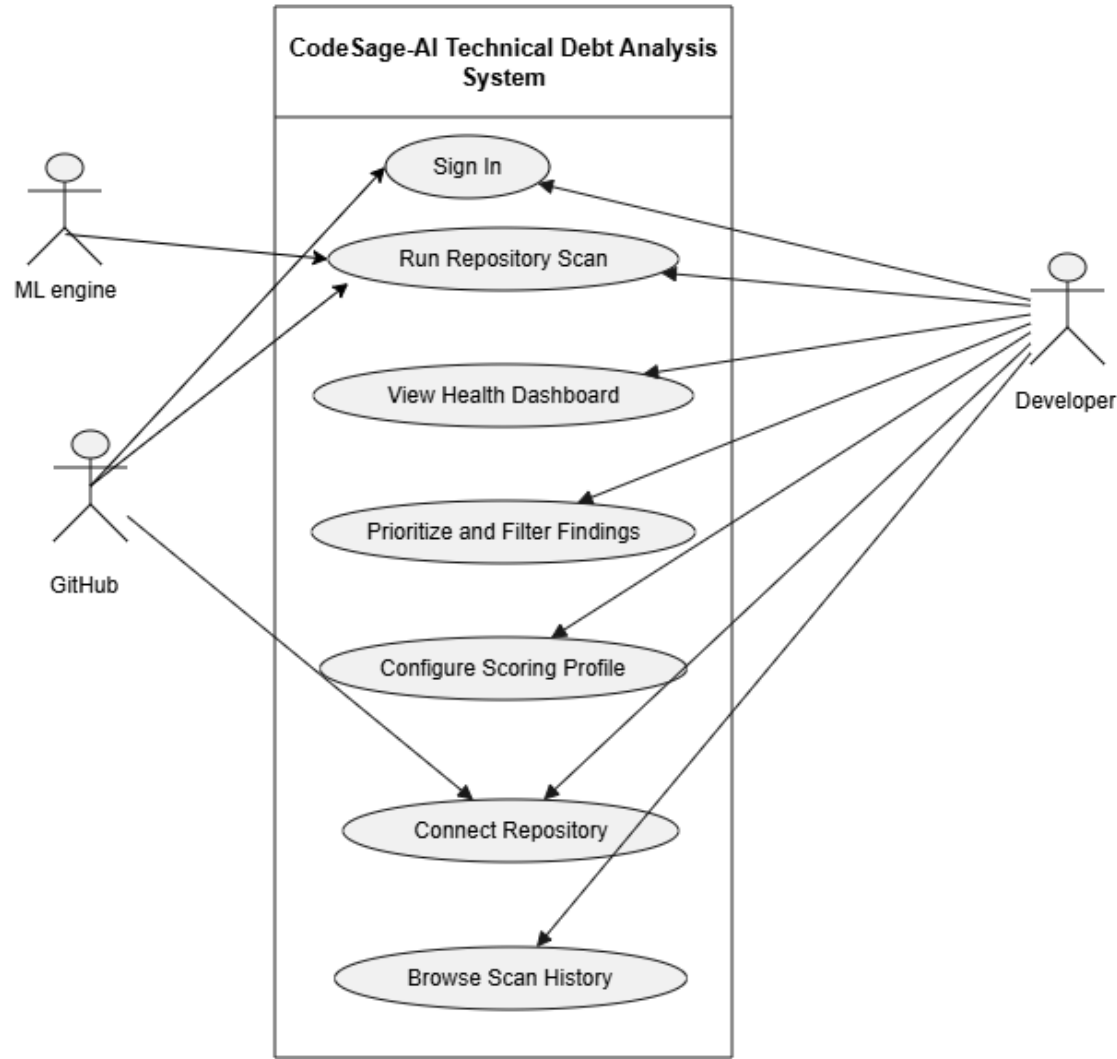
Table 4-1. Architecturally significant use cases.

ID	Use case	Actors	Why it is architecturally significant
UC-1	Sign In (Asgardeo, GitHub federated)	Developer	Establishes authenticated access and fixes the trust boundary for the whole system: the exchange with the identity provider happens in the API, so no external credential ever reaches the browser.
UC-2	Connect Repository	Developer GitHub Service	Establishes the GitHub integration and repository context required for subsequent code analysis and scanning.
UC-3	Run Repository Scan	Developer	Core analysis use case. Initiates the asynchronous analysis pipeline involving repository extraction, code metrics, SATD detection, risk prediction, scoring, and persistence.
UC-4	View Health Dashboard	Developer	Aggregates analysis results into repository health, technical-debt indicators, risk information, and visual summaries for architectural monitoring.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

UC-5	Triage & Filter Findings	Developer	Provides mechanisms to inspect and prioritize detected technical-debt findings, connecting analysis results with actionable developer decisions.
UC-6	Select / Configure Scoring Profile	Developer	Allows users to configure category weighting used by the deterministic scoring engine, making prioritization adaptable to project needs.
UC-7	Browse Scan History	Developer	Provides access to previous scan results and snapshots, supporting historical comparison and tracking of technical-debt evolution.

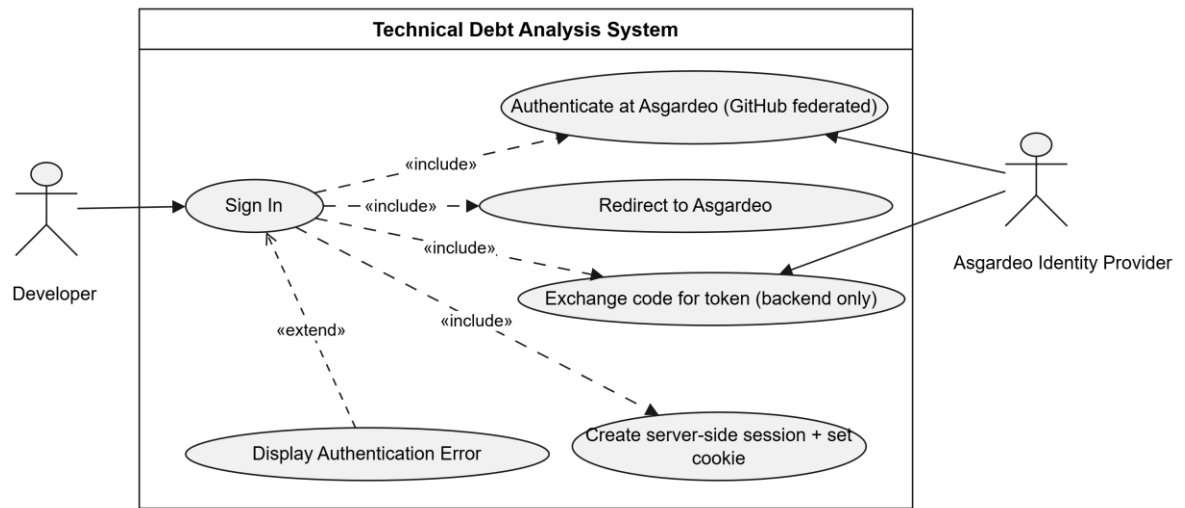
Figure 1. Use-case overview for v1.0.



4.1 Sign In

Figure 1.1. Use-case sign In.

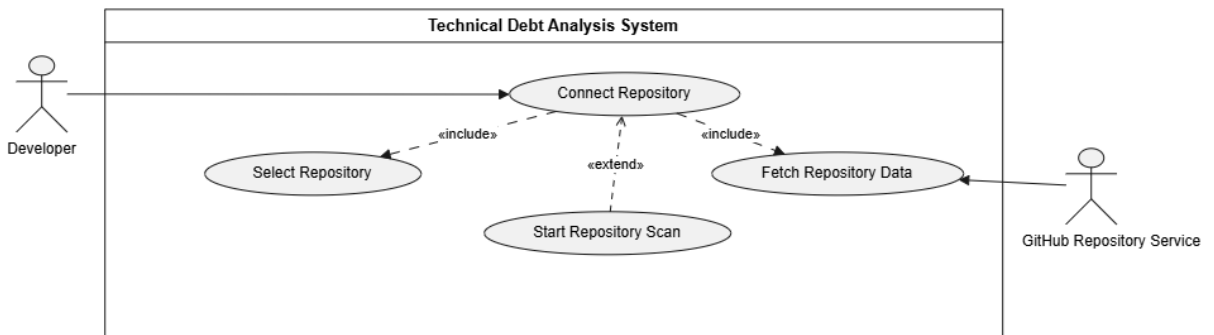
Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	



The Sign In process begins when a developer asks to sign in. The API redirects the browser to Asgardeo, which presents the sign-in methods configured for the workspace; in v1.0 that is GitHub, federated inside Asgardeo, so GitHub verifies the credentials and Asgardeo, not this system, receives the result. Asgardeo then returns the browser to the API's callback with an authorization code. The API verifies the state value it issued at the start, exchanges the code for the identity token over its own server-to-server connection, creates a session row and sets an httpOnly session cookie on the browser. On a first sign-in it also creates the user's workspace and its default scoring profile, so no later read has to cope with a workspace that has none. If the state does not verify, or the exchange fails, no session is created, an audit record is written and the user is returned to the sign-in page with an error.

4.2 Connect Repository

Figure 1.2. Use-case Connect repository.

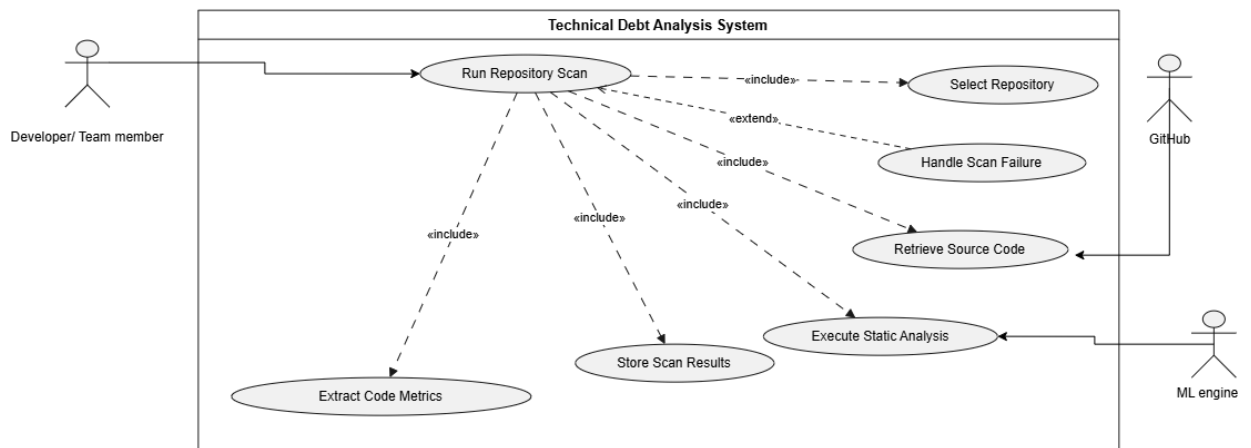


The Connect Repository process begins when a developer inputs or selects a public repository, causing the system to retrieve the metadata and the source files directly from the GitHub Repository Service into the workspace. Once the repository is connected and loaded successfully, the developer may start the scan.

4.3 Run Repository Scan

Figure 1.3. Use-case run repository scan.

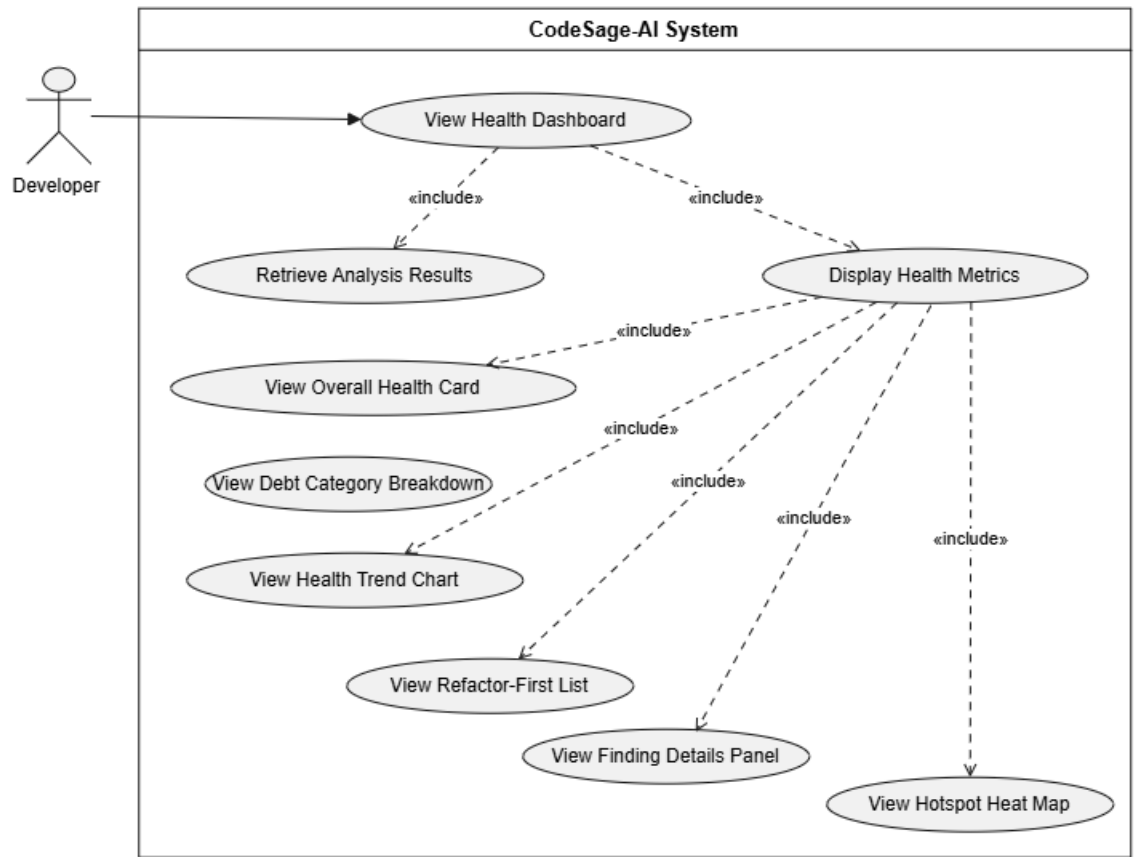
Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	



The process of running repository scanning begins the moment the developer chooses a GitHub repository. Once chosen, the system automatically downloads the code from GitHub and sends it to the ML Engine to run static analysis rules. In this process, the system Extract Code Metrics and saves the complete report in the database for the developer to review. If there is an error during the downloading or processing, the system handles it and notify the user.

4.4 View Health Dashboard

Figure 1.4. Use-case View health dashboard.



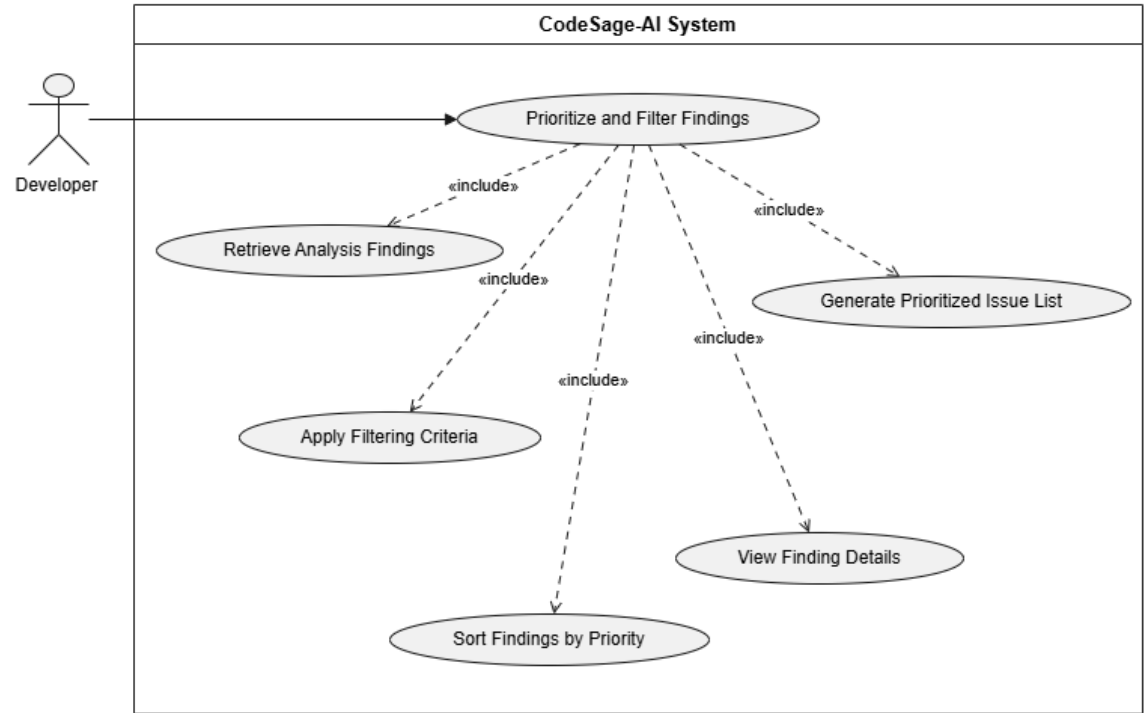
The process of viewing the health dashboard starts when a developer accesses the dashboard, prompting the system

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

to automatically retrieve analysis results and displaying the health metrics. Once loaded, the application automatically generates a report providing detailed information, metrics included such as overall score, categorization of technical debt, historical trends charts, list of prioritized refactoring lists, finding details, and a hotspot heat map for the developer to inspect.

4.5 Triage & Filter Findings

Figure 1.5.. Use-case prioritize and filter.

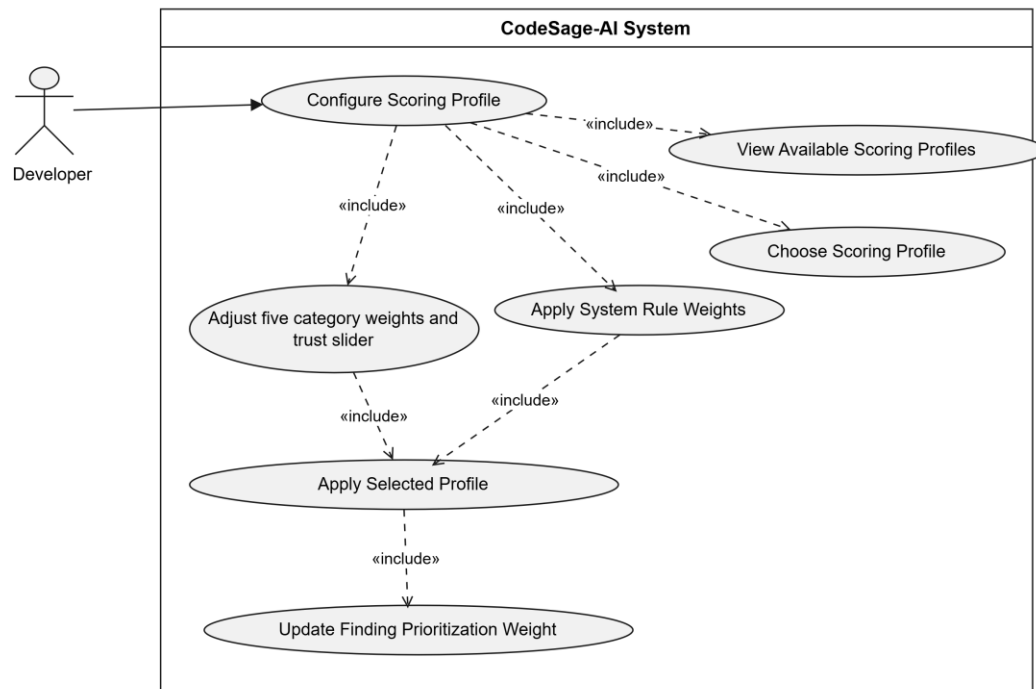


The process of prioritization and filtering starts whenever a developer asks to organize the scan results. Then the system retrieves previously stored findings and uses the selected filtering and sorting parameters. After that, the system processes the information to create a priority list of technical debt.

4.6 Select / Configure Scoring Profile

Figure 1.6. Use-case configure scoring profile.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

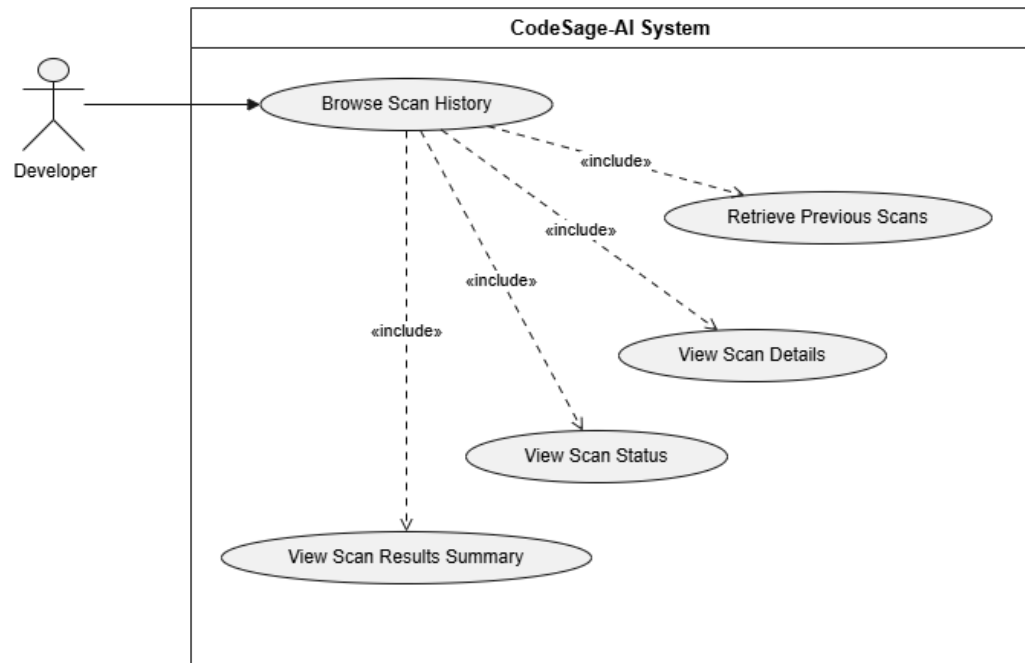


The Configure Scoring Profile process begins when a developer reviews available options and choosing a scoring profile. After that the developer customizes the parameters using sliders while the system uses the analysis logic that has been pre-defined Finally, the system combines these configurations into one and automatically updates the refactor first list.

4.7 Browse Scan History

Figure 1.7. Use-case browse scan profile.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	



The Browse Scan History process allows a developer review past static analysis activity by fetching previous analysis records from the database. When the data loads the system provides the execution states for every instance and a summary of the outputs. The Developer can then choose any past record to examine the execution log and breakdown in more details.

5. Logical View

5.1 Overview

Table 5-1. Subsystem decomposition.

Subsystem	Responsibility	Main internal parts
Frontend (Next.js)	Provides a browser-based user interface for managing repositories, controlling scans, dashboard, inspecting findings, scan history and scoring configurations. It communicates with the backend through the application API.	Next.js presentation components, dashboard views, project and branch selection, scan controls, finding-detail view, hotspot file tree, scan-history view, scoring-profile interface, API client.
Backend (FastAPI and Celery)	Implements the application and domain logic. FastAPI handles synchronous user-facing operations and is the only part of the system the browser talks to, while Celery workers perform long-running repository analyses asynchronously. The backend also derives profile-dependent scoring results from stored analysis facts.	FastAPI application services, repository and GitHub integration, analysis orchestration, Celery workers, metric and comment extraction, rule engine, scoring engine, snapshot management, dashboard services, security auditing.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Subsystem	Responsibility	Main internal parts
ML Service (Python, scikit-learn)	Performs machine-learning inference for SATD classification and file-level bug-proneness prediction. It returns prediction results to the analysis pipeline without assigning finding severity.	SATD classifier, bug-risk model, versioned model artifacts, model-version metadata.
Database (PostgreSQL)	Persists tenant-owned configuration, repository metadata, analysis history, immutable completed-analysis facts, findings, metrics, and prediction results. Profile-dependent scores are derived when results are retrieved rather than stored.	Workspace and repository data, analysis attempts, snapshots, findings, metrics, prediction data, scoring configuration, model provenance, security-audit records.

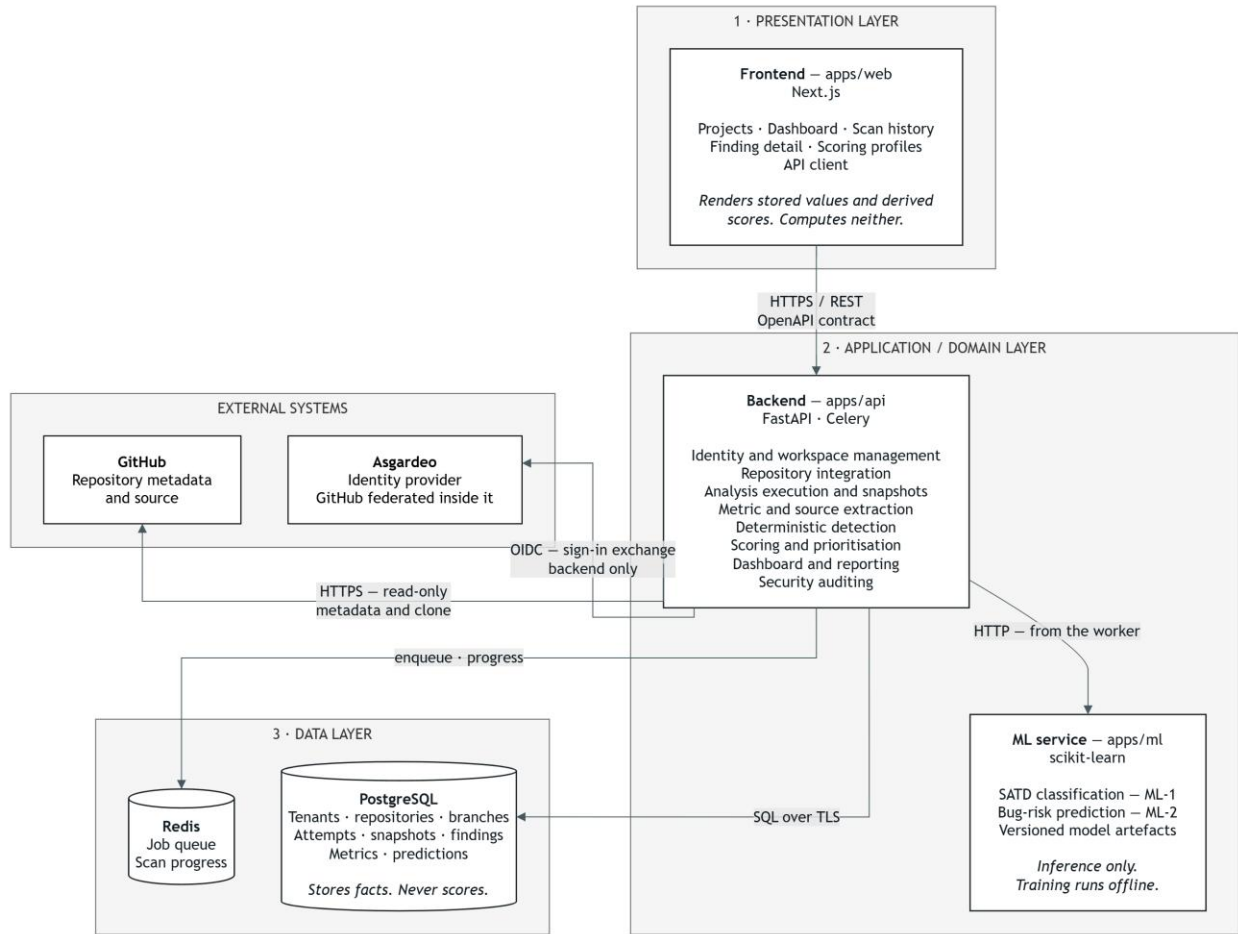


Figure 2. Logical decomposition into subsystems and layers.

5.2 Architecturally Significant Design Packages

The system is organized into a set of architecturally significant design packages, each grouping closely related classes

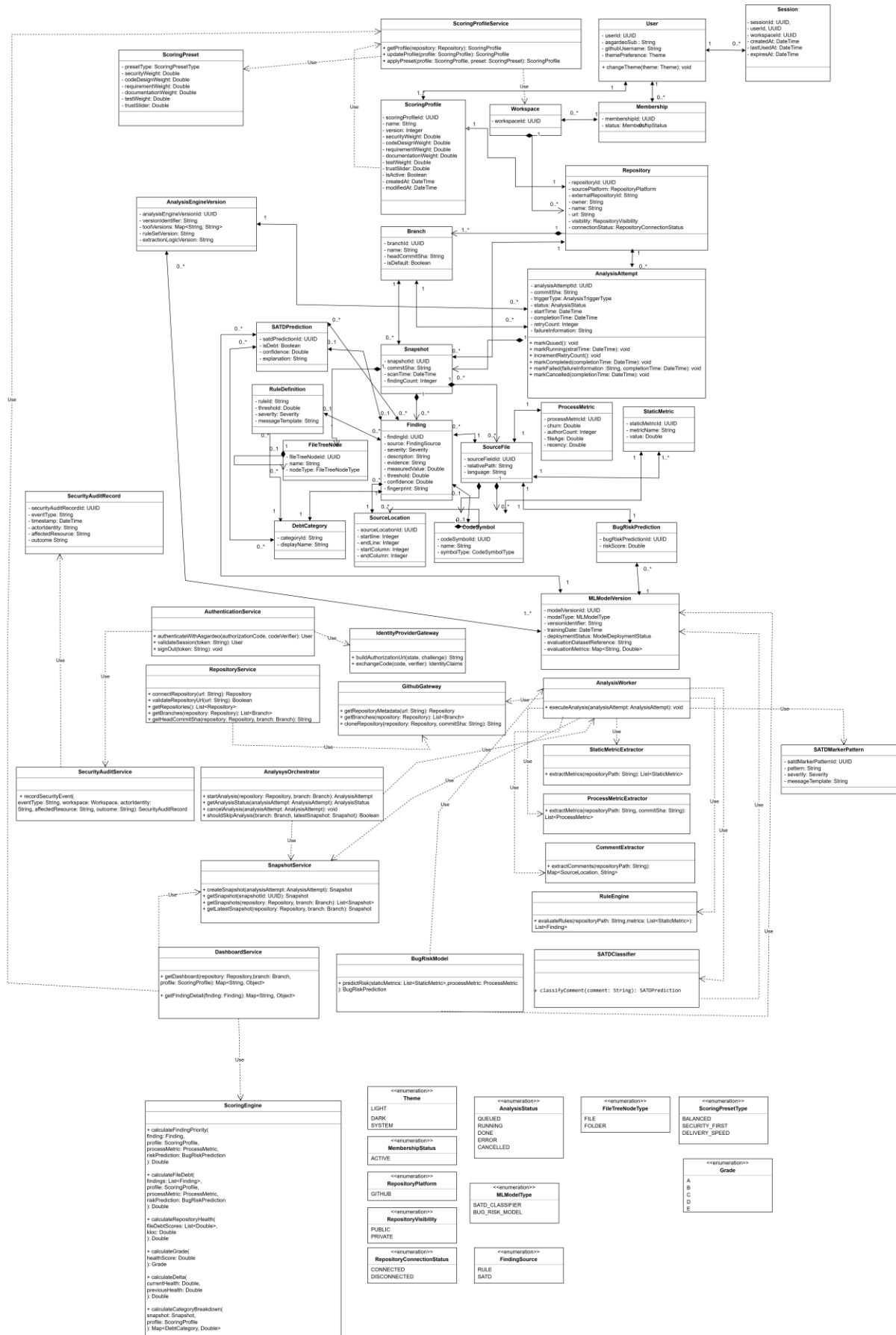
Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

according to their primary responsibilities. These packages define the major logical boundaries of the system and support separation of concerns, maintainability, and modular development. The key design packages, their classes, and their roles are summarized in the following table.

Design Package	Classes Belonging to the Package	Role of the Package
Identity and Workspace Management	User, Workspace, Membership, Session, AuthenticationService, IdentityProviderGateway	Manages authenticated users, workspace boundaries, and user-to-workspace membership. It completes the sign-in exchange with the identity provider, holds the resulting session server-side, and establishes the tenant context used to isolate repositories, analyses, and other workspace-owned data.
Branch	Repository branches, including branch name, current head commit SHA, and whether the branch is the default branch.	Stored fact
Analysis Execution and Snapshot Management	AnalysisAttempt, Snapshot, AnalysisEngineVersion, AnalysisOrchestrator, AnalysisWorker, SnapshotService	Manages the complete lifecycle of repository analysis. It records individual analysis attempts, coordinates asynchronous analysis execution, identifies the analysis-engine configuration used, and creates immutable snapshots only after successful completion of the full analysis pipeline.
Metric and Source Information Extraction	StaticMetricExtractor, ProcessMetricExtractor, CommentExtractor	Extracts the source and repository information required by downstream analysis stages. This includes static software metrics, repository-history-derived process metrics, and source-code comments used for SATD detection.
Deterministic Technical Debt Detection	Finding, RuleDefinition, SATDMarkerPattern, RuleEngine	Represents and detects deterministic technical-debt findings. It maintains rule definitions and SATD severity marker patterns and applies deterministic rules to metrics and source information to produce categorized findings with fixed severity.
Machine Learning Analysis	SATDPrediction, BugRiskPrediction, MLModelVersion, SATDClassifier, BugRiskModel	Encapsulates machine-learning-based analysis. It performs SATD classification and file-level bug-risk prediction while preserving the model-version information required for prediction provenance and reproducibility.
Scoring and Prioritization	ScoringProfile, ScoringPreset, ScoringEngine, ScoringProfileService	Defines and manages configurable scoring behavior and derives finding priorities, file-level debt, repository health, grades, category breakdowns, and related values from stored analysis facts. Scoring is performed on the read path so profile changes can re-score existing results without requiring another repository analysis.
Dashboard and Reporting	DashboardService	Assembles stored analysis facts and dynamically derived scores into the read-only representations the dashboard needs, including current and historical repository health and technical-debt information. Assembles stored analysis facts and dynamically derived scores into read-only representations required

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

		by the dashboard, including current and historical repository health and technical-debt information.
Security Auditing	SecurityAuditService, SecurityAuditRecord	Records and represents security-relevant system events. It provides an auditable history of actions and outcomes without persisting authentication secrets.
Session	One record per signed-in user: the session identifier the cookie carries, the user and workspace it belongs to, and its creation, last-use and expiry times. No identity-provider token is stored in plaintext.	Stored fact



Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Figure 3. Core domain model.

Table 5-2. Architecturally significant classes.

Class	Responsibility	Notes
User	Represents an authenticated user of the platform.	User identity is kept separate from workspace membership.
Workspace	Represents the tenant boundary and top-level owner of system data.	A workspace has one active user in v1.0, while the model supports future multi-user workspaces.
Membership	Represents the relationship between a user and a workspace.	Supports tenant membership without directly coupling users to repositories.
Repository	Represents a GitHub repository connected to the system for analysis.	Stores repository metadata and belongs to a workspace.
Branch	Represents a repository branch and its current head revision.	Analysis and historical trends are per branch
Analysis Attempt	Represents one execution attempt of the repository-analysis pipeline.	Failed and cancelled attempts are retained; only successful attempts produce finalized snapshots.
Snapshot	Represents the immutable result of a successfully completed analysis.	Stores analysis facts only. scores are derived when results are read depending on the profile.
Finding	Represents one atomic technical-debt issue detected in source code, at a file, line and symbol. Represents an atomic technical-debt issue detected in source code	A finding has source rule or satd; category and severity are fixed at detection time.
RuleDefinition	Defines a deterministic technical debt detection rule.	Each rule has a fixed category, severity, threshold, and message template.
SATDMarkerPattern	Defines deterministic marker patterns used to assign severity to SATD findings.	SATD severity is assigned from comment patterns rather than by the ML model.
SATDPrediction	Represents the output of SATD classification for a source-code comment.	Records debt/non-debt classification and category-related prediction information.
BugRiskPrediction	Represents the file-level bug-proneness result produced by the risk model.	Produces a risk score but does not create a technical-debt finding.
MLModelVersion	Represents version and evaluation metadata for a deployed machine-learning model.	Supports model provenance and reproducibility across analyses.
AnalysisEngineVersion	Represents the exact analysis-engine configuration used for an analysis attempt.	Identifies tool, rule-set, extraction-logic, and ML-model versions.
ScoringProfile	Represents the configurable values used to derive finding priorities and repository health.	Contains category weights and trust configuration.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Class	Responsibility	Notes
ScoringPreset	Represents a predefined scoring-profile configuration.	Used to initialize or reset profile values.
AuthenticationService	Completes the OpenID Connect exchange with Asgardeo, creates and validates sessions, and revokes them at sign-out.	The application service is stateless, but the session it issues is not: the session record lives in the database so that signing out ends it immediately (SRS SEC-10).
RepositoryService	Handles repository connection and retrieval of repository and branch information.	Uses the GitHub gateway for external repository access.
GitHubGateway	Encapsulates all communication with GitHub.	Handles repository metadata retrieval, branch information and repository cloning. It plays no part in authentication: identity comes from Asgardeo.
AnalysisOrchestrator	Controls the lifecycle of asynchronous repository-analysis requests.	Starts, monitors, cancels, and may skip equivalent analyses.
AnalysisWorker	Executes the repository-analysis pipeline asynchronously.	Coordinates extraction, deterministic detection, ML inference, and snapshot finalization.
StaticMetricExtractor	Extracts static software metrics from the checked-out repository revision.	Produces metrics used by rule evaluation and bug-risk prediction.
ProcessMetricExtractor	Extracts history-derived process metrics from the repository.	Produces churn, author count, file age, and recency values.
CommentExtractor	Extracts source-code comments and their locations for SATD analysis.	Unrelated comments remain transient and are not persisted.
RuleEngine	Evaluates deterministic metric thresholds and security patterns to produce rule-based findings.	Security findings are still rule findings with category security.
SATDClassifier	Classifies source-code comments as debt/non-debt and predicts SATD category.	Does not assign severity.
BugRiskModel	Predicts file-level bug-proneness from static and process metrics.	Its output influences scoring but does not generate findings.
ScoringEngine	Derives finding priority, file debt, repository health, grade, delta, and category breakdown.	Operates on the read path as a pure calculation over stored facts and the active profile
SnapshotService	Creates finalized snapshots and retrieves current or historical snapshots.	Finalization occurs only after all analysis stages complete successfully.
DashboardService	Assembles dashboard data from stored analysis facts and derived scores.	Provides read-only dashboard representations.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Class	Responsibility	Notes
ScoringProfileService	Retrieves and updates scoring profiles and applies scoring presets.	Profile changes re-score existing results without triggering a new scan.
SecurityAuditService	Records security-relevant system events.	Produces persistent audit records without storing authentication secrets.
SecurityAuditRecord	Represents a persisted security-audit event.	Stores event type, timestamp, actor identity, affected resource, and outcome.
Session	Represents one signed-in user's session, held server-side.	The browser receives only an opaque identifier for it. Deleting the record ends the session on the next request.
IdentityProviderGateway	Encapsulates every call to the identity provider.	Builds the authorization request, verifies the returned state and exchanges the authorization code. It is the only component that sees a provider token.

6. Process View

The processes. Five processes make up a running system. The **API process** is stateless and can be replicated. One or more **worker processes** run the scan pipeline. The **ML inference process** loads the two model artifacts and answers classification and risk requests. The **Redis broker** carries job messages, progress and the cancel flag. The **database process** holds everything that persists.

Table 6-1. Processes and their communication.

Process	Characteristics	Communicates to	Carries
API (FastAPI)	Stateless (request/response style)	Redis, PostgreSQL, GitHub	HTTP requests, Job enqueue, scoring
Worker (Celery)	Long running, background	Redis, PostgreSQL, ML service, GitHub	Clone → extract → detect → Score pipeline
ML inference	Long running, (request/response style)	Called by workers	Comment batches in, labels out; feature vectors in, risk scores out
Redis broker	Transient state, in-memory	API and workers	Job queue, progress percentage, cancel flag
PostgreSQL	Stateful	API and workers	All persistent state

Figure 4 draws above five processes and adds two more. The browser appears because a scan is started and polled from there. GitHub appears because both the API and the worker call it. Neither is a process this project deploys, but messages cross to both, and omitting them would hide two of the system's interfaces.

Figure 4 traces one scan from the user's click to the rendered dashboard. Each process has its own region, so every

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

arrow that crosses boundary is a message between two processes, and the label on that arrow names the protocol it travels over. GitHub is drawn as a seventh process(external) because both the API and the worker call it, in two different ways. The scan phase defined in SRS FR-6 is written on the activities that change it, so the state machine idle → queued → running NN% → done | error | cancelled can be followed through the figure.

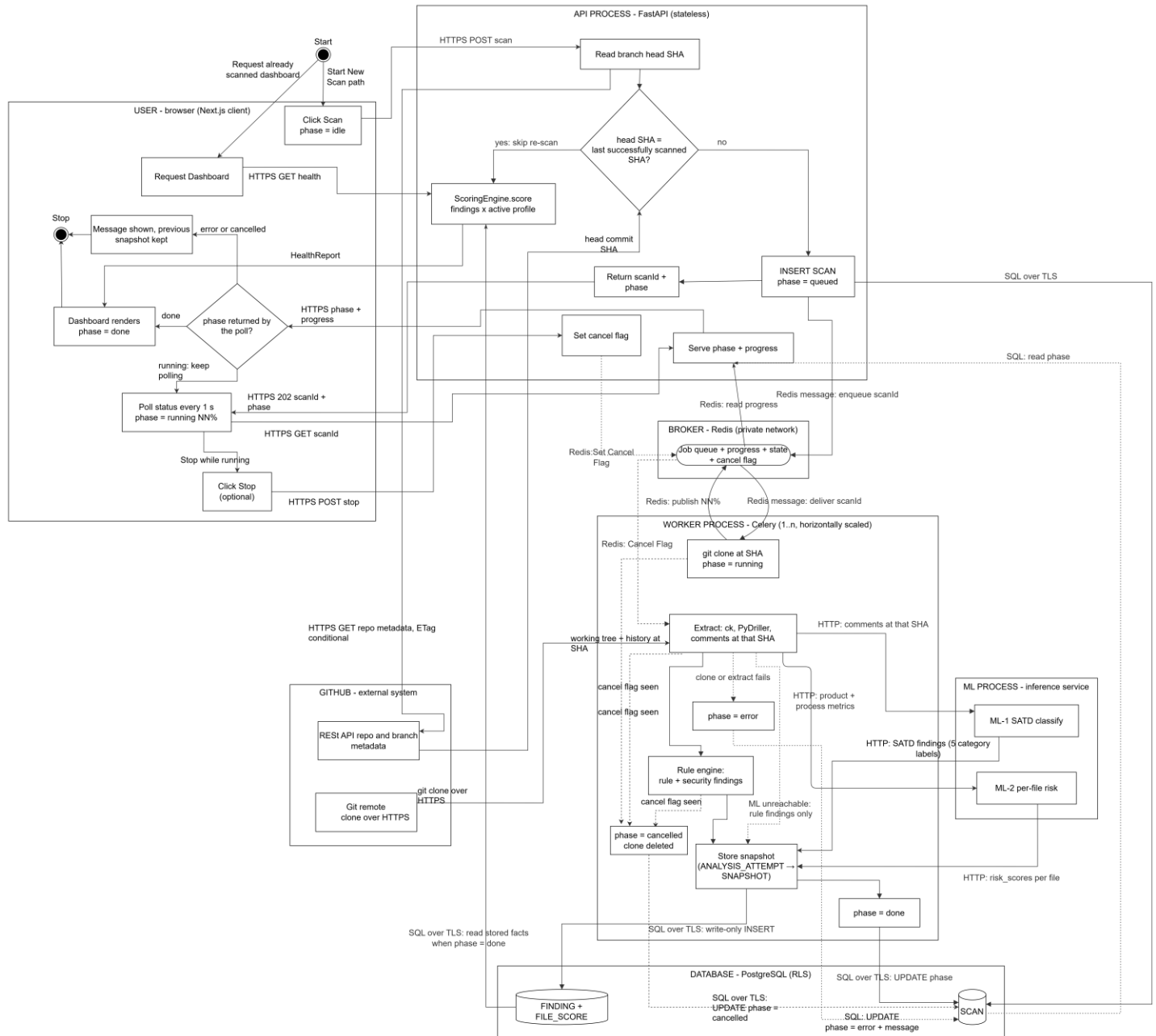


Figure 4. Scan activity, including skip for unchanged repositories and cancel.

Figure 4 records eleven architectural decisions. They are stated below, each with the requirement it serves and the consequence of deciding it differently.

Scoring is in the API process, not the worker process. The write path ends in the worker lane at "Store snapshot". ScoringEngine appears only in the API lane, on the read path. This is the rule that lets a user change a

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

scoring profile without running a new scan(SRS FR-20, FR-21). If scoring were a pipeline stage, every weight change would require a re-scan of every snapshot.

Skip for unchanged is decided in the API, before the job is queued. The API reads the branch head SHA from GitHub and compares it with the last scan of that branch. If they are equal, no job is queued and no worker is used. The check costs one conditional REST call and one indexed database read, so the user receives a dashboard within the one second allowed by SRS PERF-02. Deciding this in the worker instead would mean queuing a job, occupying a worker, and cloning a repository only to discover that nothing had changed.

The comparison uses the last successful scan, not the last scan. A cancelled or failed scan leaves an ANALYSIS_ATTEMPT row and no SNAPSHOT at all, because the worker stopped before the finalize stage. That is why the comparison is made against the SHA of the most recent attempt that produced a snapshot: comparing against any attempt would let the system skip the work and then serve a snapshot that was never written. The split between the two tables is what makes this structural rather than a condition every query has to remember.

GitHub is contacted in two different ways. The API uses the GitHub REST API for repository and branch metadata, with ETag conditional requests so that repeated reads usually cost no rate-limit quota. The worker uses git clone over HTTPS to obtain the code, which consumes no REST quota at all. This is why the rate limits are avoided rather than managed

The API answers before the work begins. POST /api/repos/{repo_id}/scan inserts the ANALYSIS_ATTEMPT row, enqueues the job and returns a scan identifier with phase = queued. The client then polls GET /api/repos/{repo_id}/scan/{scan_id} once per second (SRS Table 3.107). The interface stays usable while the scan runs, as SRS PERF-05 requires. Running the pipeline inside the request would block the connection for minutes and make the requirements impossible to meet.

PostgreSQL holds the phase and Redis holds only the percentage. The status endpoint reads ANALYSIS_ATTEMPT.phase from the database and the progress percentage from Redis. The separation follows from what each store guarantees. Redis is a broker, so losing a percentage when it restarts costs nothing, because the next poll produces a new one. Losing the fact that a scan failed would break SRS SP-13, which requires the final phase and its error message to be recoverable from the database alone. Every terminal phase is therefore written to ANALYSIS_ATTEMPT by the process that reaches it.

Cancellation is cooperative rather than forced. The API does not stop the worker. It sets a flag in Redis and returns immediately. The worker reads that flag between stages and stops at the first boundary it reaches, deletes its clone and writes phase = cancelled to its ANALYSIS_ATTEMPT row. Storing the snapshot is outside this region: once the worker begins writing findings it completes the write. Terminating the process during a write would leave a partial snapshot, and SRS FR-6 requires the previous snapshot to remain intact after a cancellation. The cost of this choice is response time, because a user who presses Stop waits until the current stage ends.

The cancel result reaches the user through the polling channel. Because the worker writes phase = cancelled to the same row the status endpoint already reads, no separate notification path is needed. The user learns that the scan has really stopped when the next poll returns idle. The three non-running phases, done, error and idle, all arrive by the same route.

A failed scan is recorded in the database, not only in the logs. The worker writes phase = error and the error message onto the existing ANALYSIS_ATTEMPT row. This satisfies SRS SP-13: a failure reported by a user can be diagnosed from the database without reading server logs. No SNAPSHOT was created, so the previous snapshot is unaffected and remains what the dashboard shows.

The two machine-learning models are independent and are not chained. ML-1 and ML-2 take different inputs, produce different outputs and exchange no data. ML-1 reads the source comments and produces SATD findings, predicting category only. It can produce four of the five categories; security comes from the rule engine alone (SRS FR-9.3). Severity for a SATD finding comes from the deterministic marker table in SRS Appendix C.2, not from the model (SRS FR-9.2). ML-2 reads the CK product metrics and the four PyDriller process metrics and produces one risk_score per file. It produces no findings at all (SRS FR-10).

The machine-learning models can be skipped. Both models run in one inference container, so they are reachable or unreachable together. The dashed edge that bypasses the lane leaves the worker, because the worker is where the call is attempted and therefore where the failure is observed. When the service is unreachable the worker

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

persists a valid snapshot: all rule and security findings are present, no SATD findings appear, and no risk score is recorded for any file. A missing risk score is reported as absent rather than as zero, because zero would mean the file was assessed and found safe; with no score the risk factor falls back to 1.0 and boosts nothing.

6.1 The extraction boundary

Git history enters the pipeline as numbers, never as text. Text produces findings, and a finding must map to a file: line that the user can open. So, text is read from the checked-out tree at the scanned commit. History produces metrics for the past 90-days, but numeric values enter the scanning pipeline.

Table 6-2. What may and may not enter the pipeline.

Input	Used at scan time (Yes/No)	Reason
Source comments at the scanned SHA	Yes	The SATD classifier reads comments
Source files at the scanned SHA	Yes	CK, then the rule engine and ML-2 use source files
Commit history reachable from that SHA	Yes	Four numbers: churn, author count, file age, recency
Commit message text	No	It has no file: line, so a finding could not point anywhere
Pull requests, issues, GitHub API metadata	No	Pull requests and issues not considered in v1.0. Api quota not used during a scan
Previously stored snapshots	No	History is read only to draw trends and deltas, never to detect or score

Two consequences follow.

A scan is a pure function of the repository at one commit. The result depends on the tree and reachable history at that SHA plus a fixed model version, never on a previous scan row. This is what makes the skip branch of decision in Figure 4 safe, and what makes snapshots reproducible. Since, a scan is independent of prior scans, not of git history, because ML-2 reads that history as numbers.

The churn window is anchored to the commit, not to the clock. The 90 days are measured backwards from the scanned commit's committer date, never from scanned time.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

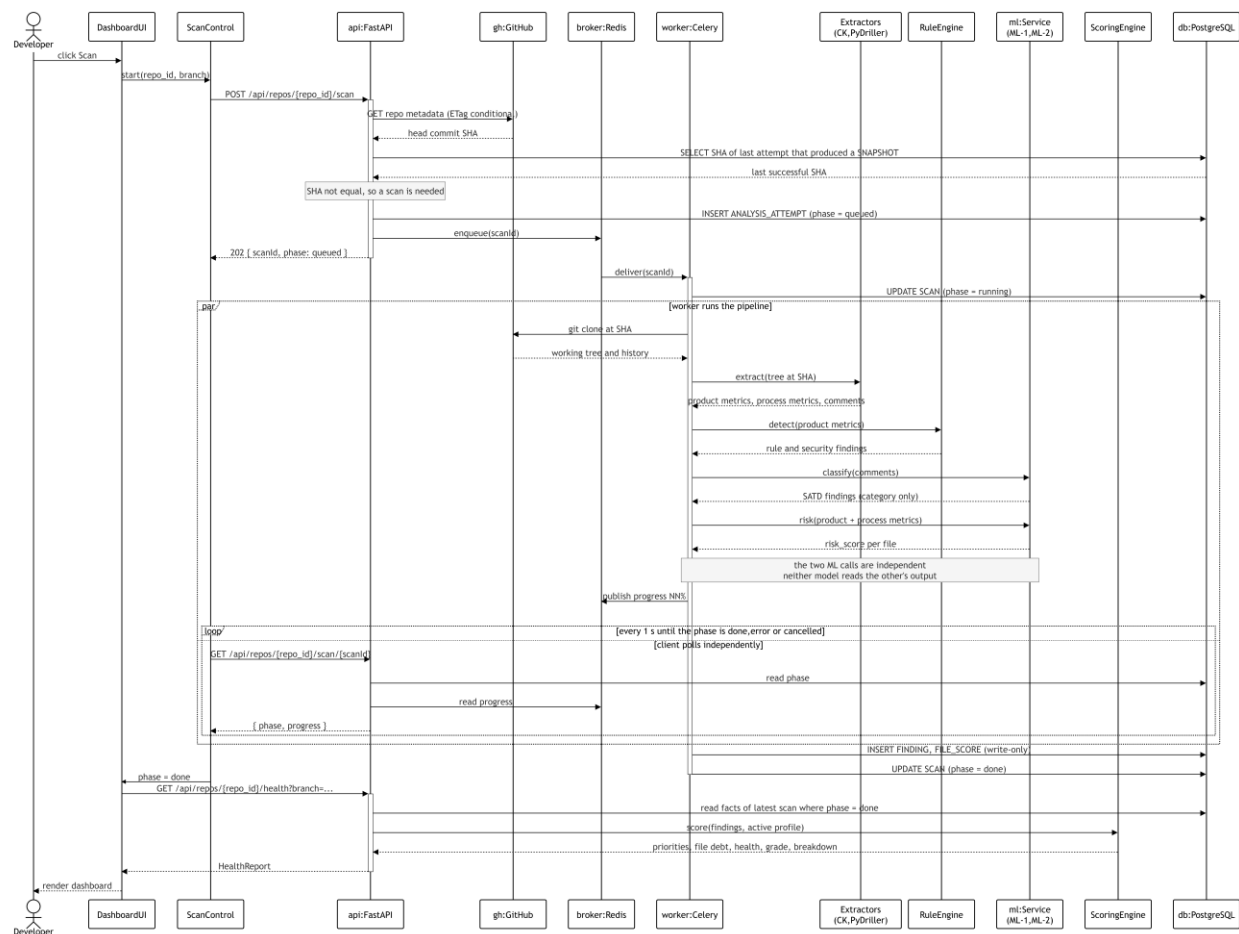


Figure 5. Run a scan sequence, successful path

Figure 5 shows the same scan as Figure 4, but as an ordered exchange between the objects that carry it out. Where Figure 4 answers "which process does what", Figure 5 answers "in what order, and who waits for whom".

The figure shows the successful path only. Cancellation and failure are drawn in Figure 4 instead. A sequence diagram states one scenario well, and adding two mutually exclusive endings to it would make the main path harder to read rather than easier. Figure 4 is the right place for alternative flows because an activity diagram is built around branching.

The ordering carries the decisions below.

The API consults GitHub and the database before it queues anything. It reads the branch head SHA from GitHub, then reads the SHA of the last scan whose phase is done. Only when the two differ does it insert an ANALYSIS_ATTEMPT row and enqueue a job. Comparing against the last successful scan is what stops a cancelled scan from being mistaken for a stored snapshot.

The API replies before the work starts. The 202 carrying the scan identifier is returned as soon as the job is on the queue. The activation bar on the API ends there. Everything after that point happens without a client connection being held open, which is what SRS PERF-05 requires.

The worker never calls the API. It records its phase by writing to ANALYSIS_ATTEMPT and its progress by publishing to Redis. The API serves the polling client from those two sources. This keeps the dependency direction one way and matches the deployment view in Figure 7.

The polling loop and the pipeline are concurrent. They are drawn as parallel fragment because the client polls while the worker works. Placing the loop before the worker starts would describe a synchronous system and would contradict the design.

The status endpoint reads from two places. The phase comes from PostgreSQL and the percentage from Redis. A

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

lost percentage can be recomputed by the next poll, whereas a lost failure would break SRS SP-13.

The two model calls are independent. They are drawn as two separate pairs, not as a chain. Neither model reads the other's output, so an implementation may issue them together.

The two client objects have separate responsibilities. ScanControl owns the scan lifecycle and stops when the poll returns done. It then hands over to DashboardUI, which issues the dashboard read and renders the result. Keeping the request and the render on the same object means every reply returns to the object that asked for it.

Finally, ScoringEngine is invoked by the API, after the worker has finished and the client has asked for the dashboard. It is never invoked by the worker.

6.2 Applying a scoring profile

A profile change is the only other user initiated write in v1.0, and it is deliberately the opposite of a scan in every way. Nothing is queued, no worker wakes and no snapshot row is written (SRS FR-20, FR-21).

The full workflow, step by step.

The Profiles screen loads. It reads GET /api/profiles/active and sets the sliders to the values that are currently set.

The user picks one of the three presets, or drags the five weight sliders and the trust slider directly. Balanced is the workspace default. Nothing is sent to the server while the user drags. The values live in the browser only.

The user clicks Apply.

The client sends PUT /api/profiles/active. The body carries the complete profile, which is the five weights and trust_s. The server validates the values and clamps them. Weights are clamped to the range 0.1 to 3.0, and trust_s to the range 0 to 1.

The server writes both rows in one transaction. It writes the five weights and trust_s onto the workspace's SCORING_PROFILE row and marks that row active. Six numbers change. That is the whole write. Exactly one profile can be active per workspace because a partial unique index on the workspace column, restricted to active rows, makes a second one impossible to insert - a guarantee the database holds rather than one the application has to remember.

The server returns the profile as it was stored, after clamping. The screen therefore shows the values that are really in force, not the values the client sent.

The client re-reads GET /api/repos/{repo_id}/health?branch; the same URL it always uses. No profile appears in it.

The server reads the stored findings and the per-file facts, passes them to ScoringEngine, and returns the re-scored dashboard.

Both endpoints are standard. SRS Table 3.106 defines them, so this section describes an agreed interface rather than proposing a new one. GET /api/profiles/active returns the workspace's active profile and seeds the screen when it loads, while PUT /api/profiles/active applies a profile the user has adjusted. FR-20 sets out the contract that both follow, requiring that a profile be applied in "a single idempotent write carrying the complete profile", and that dragging a control "changes client state only; no request is issued until the user confirms with Apply". The same requirement adds that the server "clamps every weight on write and returns the stored profile", so that the client can confirm what was actually saved rather than assuming that the values it sent were accepted.

Why PUT and not PATCH. PUT carries the meaning "make this resource look exactly like this", so the body it takes is the complete profile rather than a description of what has changed within it. The practical benefit of that distinction is that retrying the request after a dropped response cannot apply the same adjustment twice, which matters here because the dependent read in step 8 follows the write immediately and would otherwise render a dashboard matching no profile the system holds.

Why profile is not in the URL. FR-20 settles the question directly, stating that "the active profile is server-side state scoped to the workspace, so the read endpoints are unchanged and carry no profile parameter." The architectural reasoning behind the requirement is straightforward, because if the profile travels in the query string, every read endpoint would gain a parameter each time the profile changed shape, and the scoring formula would gradually leak into the API surface. SRS Table 3.106 shows the outcome of that decision, since GET /api/repos/{repo_id}/health?branch= takes a branch and nothing further, deriving its scores under whichever profile is active at the moment the request is served.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Table 6-3. The two write paths compared.

Aspect	Run a scan	Apply a profile
Request	POST /api/repos/{repo_id}/scan	PUT /api/profiles/active
Handled by	API → Redis → Celery worker	The API process alone
Writes	A new ANALYSIS_ATTEMPT and, on success, an immutable SNAPSHOT with its FINDING, metric and prediction rows	Six numbers on one SCORING_PROFILE row
Duration	Seconds to minutes, polled	One round trip
Effect on findings	Creates them	Leaves them completely untouched

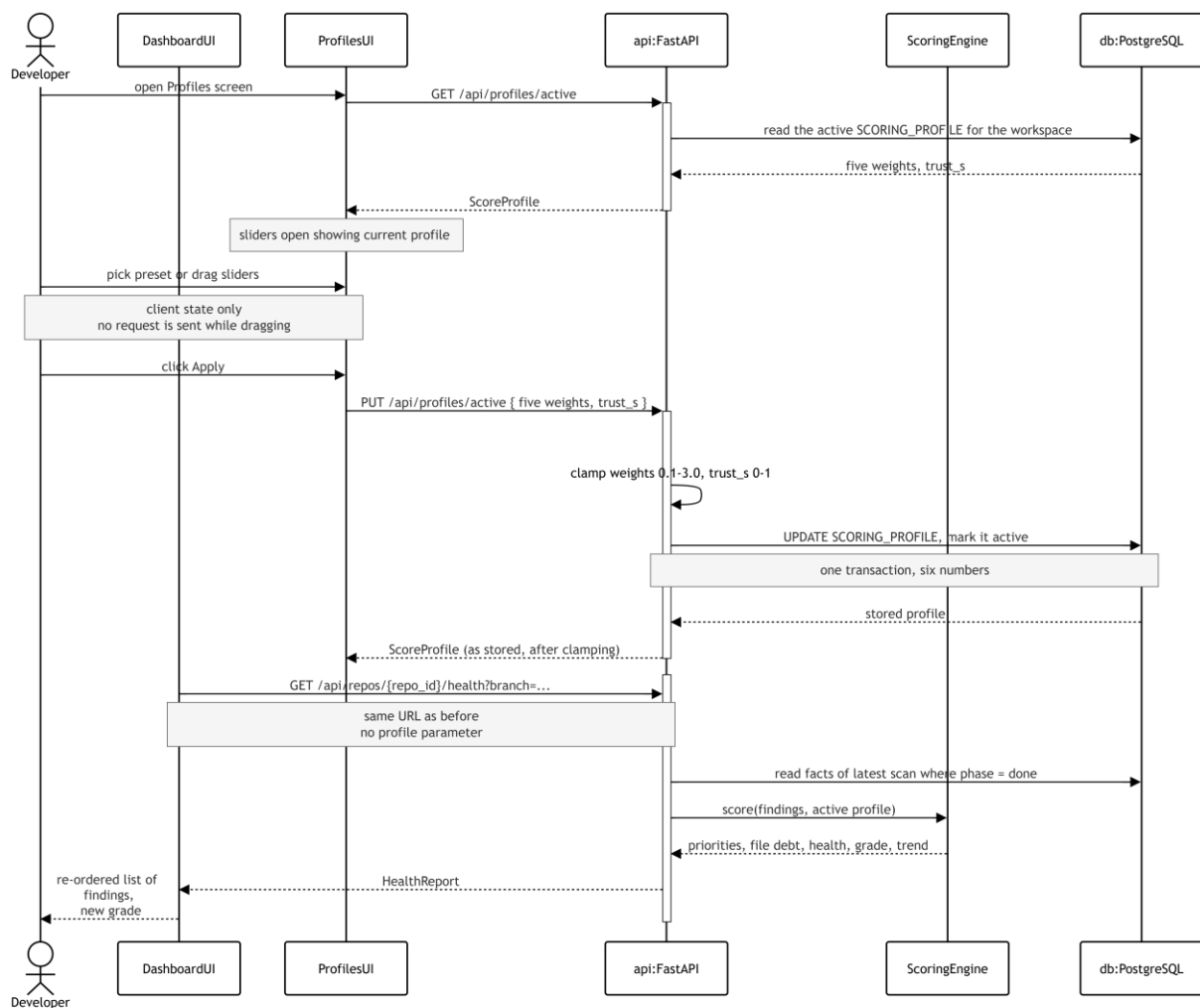


Figure 6. Apply a profile sequence.

The decisions recorded in the figure are set out below.

Nothing is sent to the server while the user drags. The slider positions remain client state until Apply is pressed, which is what SRS FR-20 requires. Issuing a request on every slider movement would place a write on the server for

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

each pixel of travel, and each of those writes would in turn have to be validated, clamped, stored and read back before the interface could display a confirmed value.

The write is a single transaction covering six numbers. The five category weights and the trust slider are written to SCORING_PROFILE and that row is marked active in the same transaction, so no reader can ever observe one without the other. No ANALYSIS_ATTEMPT, SNAPSHOT or FINDING row is touched anywhere in the exchange, which is precisely what SRS FR-21 means when it states that changing a profile creates no snapshot. The server sends back the final saved settings after adjusting them to fit allowed limits. This lets the user see the true values used for their scores. Without this, the app might falsely show an unadjusted input (like 5.0) while the server actually uses a limited value (like 3.0)

The dependent read is issued against the same URL as before. GET /api/repos/{repo_id}/health?branch=; carries no profile parameter, for the reason given earlier in this section: the active profile is server-side state belonging to the workspace (SRS FR-20).

ProfilesUI performs the write and DashboardUI performs the read. The two objects are drawn separately for the same reason they are separated in Figure 5, namely that the object issuing a request should also be the object receiving the reply. ProfilesUI signals that a profile has been applied, and DashboardUI then carries out the read it already owns. **Three properties follow from this shape.**

The read endpoints remain unparameterised, so the API surface does not grow as the profile grows.

The PUT is idempotent by construction, because its body carries the complete profile rather than a description of a change to it. Retrying the request after a dropped response therefore cannot leave a partially applied profile, which matters because the client issues a dependent read immediately afterwards.

The profile is shared rather than held per tab. A reload, a second browser tab and a second member of the team all resolve to the same active profile, so the profile name displayed on the trend chart (SRS FR-14) always refers to something that genuinely exists on the server.

Clamping is a server-side rule rather than a client convenience (SRS FR-20). The client clamps its sliders so that the controls behave sensibly under the user's hand, but the server clamps for a different and stronger reason: repo_health is calibrated against the constant k, so a single unclamped weight arriving from any client would render every stored grade incomparable with every other.

6.3 The visibility floor

SRS FR-24 requires that a critical security finding remains visible however the active profile is set. Meeting that requirement is a responsibility of ScoringEngine, and the architecture satisfies it through three mechanisms acting together rather than through any single check, because one check placed somewhere in the scoring path could later be removed or reordered without anything else in the system appearing to fail.

Table 6-4. The three mechanisms of the visibility floor.

No.	Mechanism	Why it cannot be bypassed
1	Severity is assigned at detection and is not user-configurable	The rule register fixes a hardcoded secret at Critical and no profile control writes to FINDING.severity, so the value cannot be lowered from the interface at all.
2	Security findings bypass the trust slider	source_trust is held at 1.0 for the security category (SRS FR-11), so moving the slider alters rule_trust and ml_trust while leaving security findings entirely unaffected by it.
3	ScoringEngine pins critical security findings into the visible list	The pin overrides the computed order, so even the minimum security weight of 0.1 cannot push such a finding below the point at which the interface stops displaying it.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

6.4 Signing in

Sign-in is the third exchange worth describing on its own, because it is where the system's trust boundary is drawn. The requirement is SRS FR-1, and SRS SEC-17 to SEC-20 constrain how it may be met.

The exchange runs in the API, not in the browser. When a user asks to sign in, the API generates a single-use state value and a PKCE verifier, keeps both server-side, and redirects the browser to Asgardeo carrying the state and the derived challenge. Asgardeo presents whichever sign-in methods the tenant has configured - GitHub in v1.0 - and returns the browser to the API's callback with an authorization code. The API checks that the state matches the one it issued, then exchanges the code and the verifier for an identity token over its own connection to Asgardeo. The browser is not part of that exchange and never sees the token.

What the browser receives instead is a session cookie. The API creates a session row, and sets a cookie holding nothing but that row's identifier, marked httpOnly so JavaScript cannot read it, Secure so it travels only over TLS, and SameSite=Lax so another site cannot cause the browser to send it on a state-changing request. Three properties follow. A cross-site scripting fault cannot steal a credential the page cannot read. Signing out deletes the session row, so the cookie stops being accepted on the very next request, which is what SRS SEC-10 requires and what a self-contained token could not offer without a revocation list that would be most of a session store anyway. And because no provider token is ever stored in the browser, there is nothing in the browser worth stealing.

Authorization is decided before the handler runs. Every route except the two that begin and complete sign-in, and the liveness probe, resolves the session first and rejects the request with 401 when there is none. The same dependency then binds the caller's workspace to the database transaction, so Row-Level Security has a tenant to filter on. Because that binding is the same dependency that opens the session, a handler cannot accidentally run without a tenant: it would have no database session to use. This is what makes SRS SEC-18 structural rather than a convention.

What the system stores about a user is deliberately small: the stable subject identifier issued by Asgardeo, a display name and an email address. There is no password, because the system never sees one, and no GitHub token, because v1.0 clones public repositories anonymously and therefore never acts at GitHub on a user's behalf. Keying the user on the subject identifier rather than on the email address matters for the same reason: an email address can be changed by its owner, and the subject identifier cannot.

Two consequences reach the rest of the architecture. Adding a sign-in method later - Google, or a username and password for the reviewers and stakeholders of a later release - is a configuration change inside Asgardeo, because this system integrates with the provider and not with each method behind it. And the identity provider is a hosted dependency, so an outage of it stops new sign-ins while existing sessions continue to work; SRS REL-01 excludes external-service outages from the availability target for exactly this class of dependency.

7. Deployment View

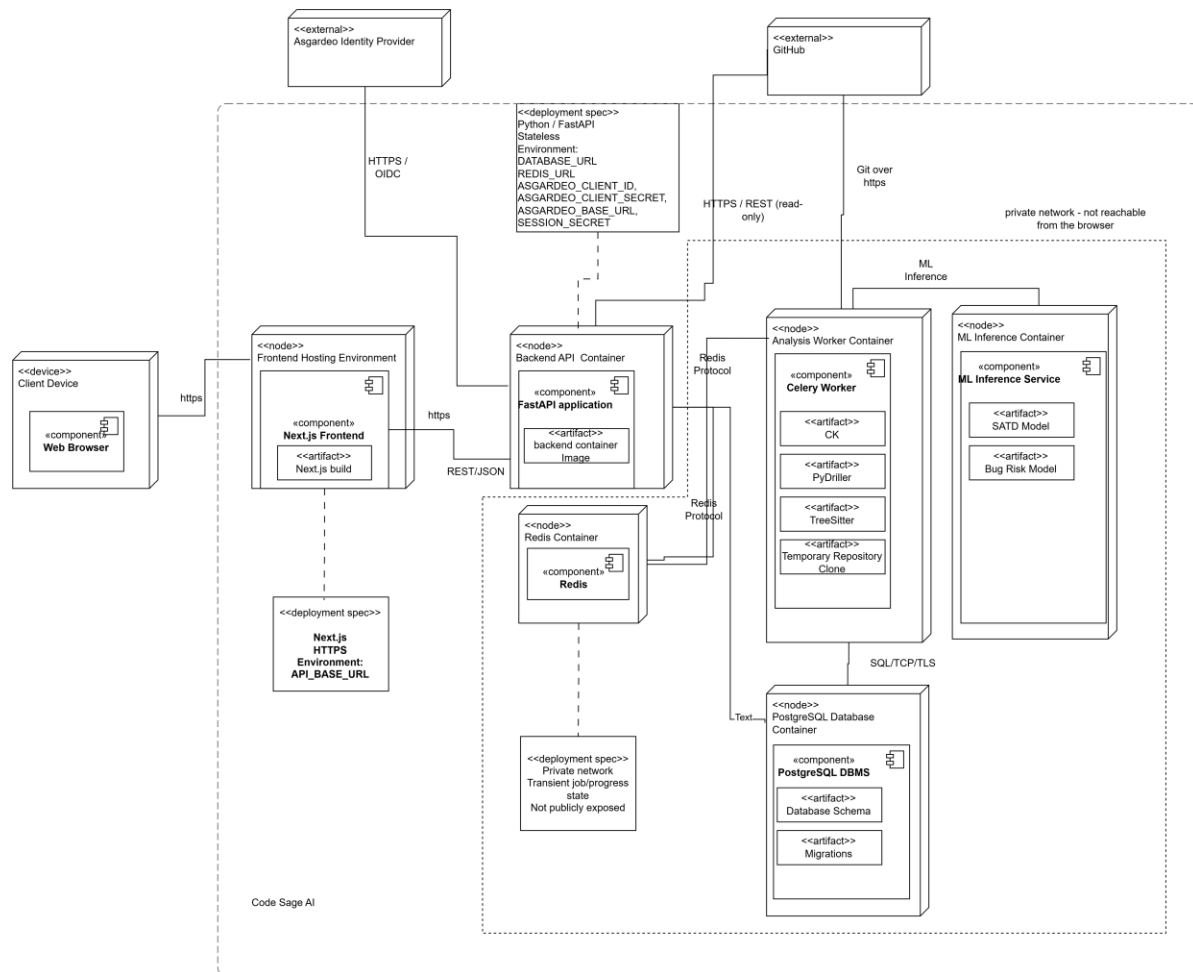


Figure 7. Deployment for v1.1.

Table 7-1. Physical nodes and the processes mapped onto them.

Node	Processes hosted	Connections
Client device	Web browser executing the client-side web application and rendering the Code Sage AI user interface.	Connects to the frontend over HTTPS. Makes application/API requests over HTTPS/JSON through the web application
Frontend container	Next.js frontend and deployed Next.js build. Handles presentation, navigation, dashboard rendering, user interactions, and API-client communication.	Receives HTTPS requests from the client browser. Communicates with the backend API using HTTPS/JSON REST.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Node	Processes hosted	Connections
Backend container	FastAPI application, acting as the Backend-for-Frontend. Handles authentication and session issue, repository/project operations, branch retrieval, dashboard and analysis-history requests, scoring profiles, scan submission, status polling, and cancellation.	Receives HTTPS/JSON REST requests from the browser and is the only backend process reachable from outside the private network. Uses Redis for task enqueueing and progress, PostgreSQL for persistent data, Asgardeo over HTTPS for the sign-in exchange, and the GitHub REST API for repository metadata.
Worker container(s)	Celery workers executing repository-analysis jobs; static analysis and repository-mining tools including CK, PyDriller, and Tree-sitter; temporary repository clones. Multiple instances may run concurrently.	Receives tasks through Redis; communicates with the ML inference service for predictions; accesses PostgreSQL for analysis state/results, clones repositories from GitHub using Git over HTTPS.
ML container	ML inference service, versioned SATD classification model and bug-risk prediction model.	Receives inference requests from analysis workers and returns SATD classifications/categories and file-level risk scores. Communication remains within the private network.
Redis broker	Redis message broker/task queue carrying analysis jobs and progress state.	Private connection between the backend API and Celery workers using the Redis protocol. Not publicly exposed.
PostgreSQL	PostgreSQL DBMS, application database schema, stored application/analysis data, and versioned database migrations.	Accessed by the backend API and analysis workers using SQL/PostgreSQL wire protocol over TLS through the private network.
Identity provider (external)	Asgardeo, hosting the sign-in methods and issuing identity tokens. Not deployed by this project.	Reached over HTTPS by the backend container only. The browser is redirected to it during sign-in but never exchanges a token with it directly.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

8. Implementation View

8.1 Overview

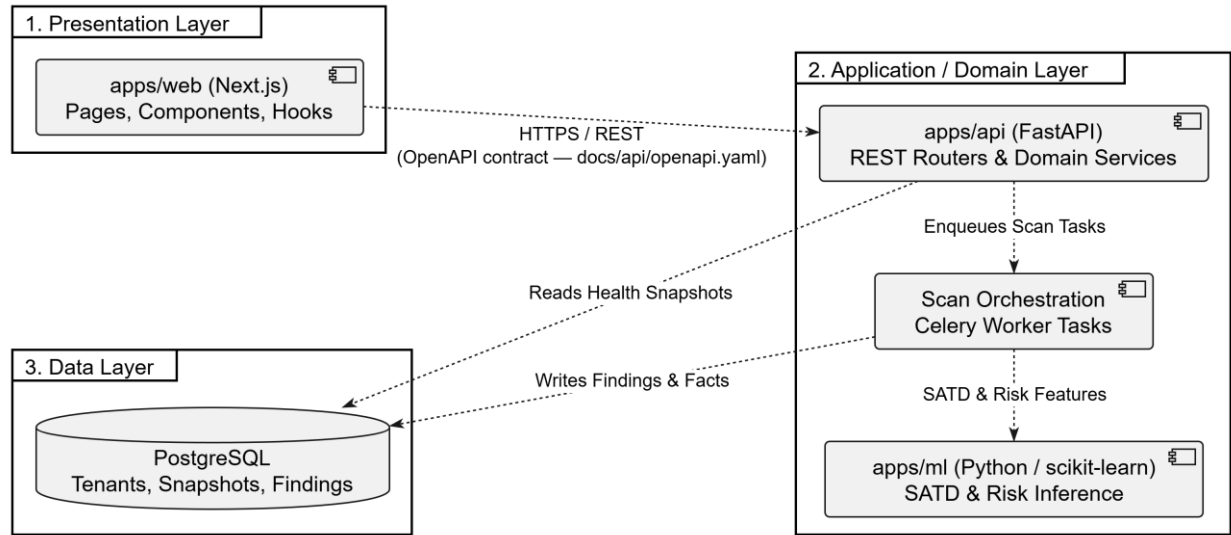


Figure 8. Implementation layers and their components.

Table 8-1. The three layers.

Layer	What belongs in it	Rule for inclusion
Presentation	Next.js frontend, UI pages, dashboards, charts, repository/project management screens	Include components that directly handle user interaction and presentation of information.
Application / Domain	FastAPI API, analysis orchestration, SATD detection, technical-debt analysis, bug-proneness prediction, prioritization logic, Celery tasks	Include business logic, application services, use-case orchestration, and AI/analysis functionality.
Data	PostgreSQL database, database models/repositories, Redis, GitHub repository data access	Include components responsible for data persistence, retrieval, caching, and external data access.

8.2 Layers

Table 8-2. Rules that govern the layers.

Rule	What it requires
Volatile libraries sit behind one boundary each	External libraries and tools are accessed through dedicated interfaces or adapters.
Thresholds and weights are configuration, not code literals	Thresholds and scoring weights are stored in configuration rather than hard-coded.
Models are versioned artifacts loaded at runtime	ML models are versioned separately and loaded at runtime when required.
The presentation layer never reaches the database	The frontend accesses data only through the application/API layer and direct database access is forbidden.
Business calculations remain in the application layer	Scoring and prioritization calculations are performed by application logic, not in the database.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

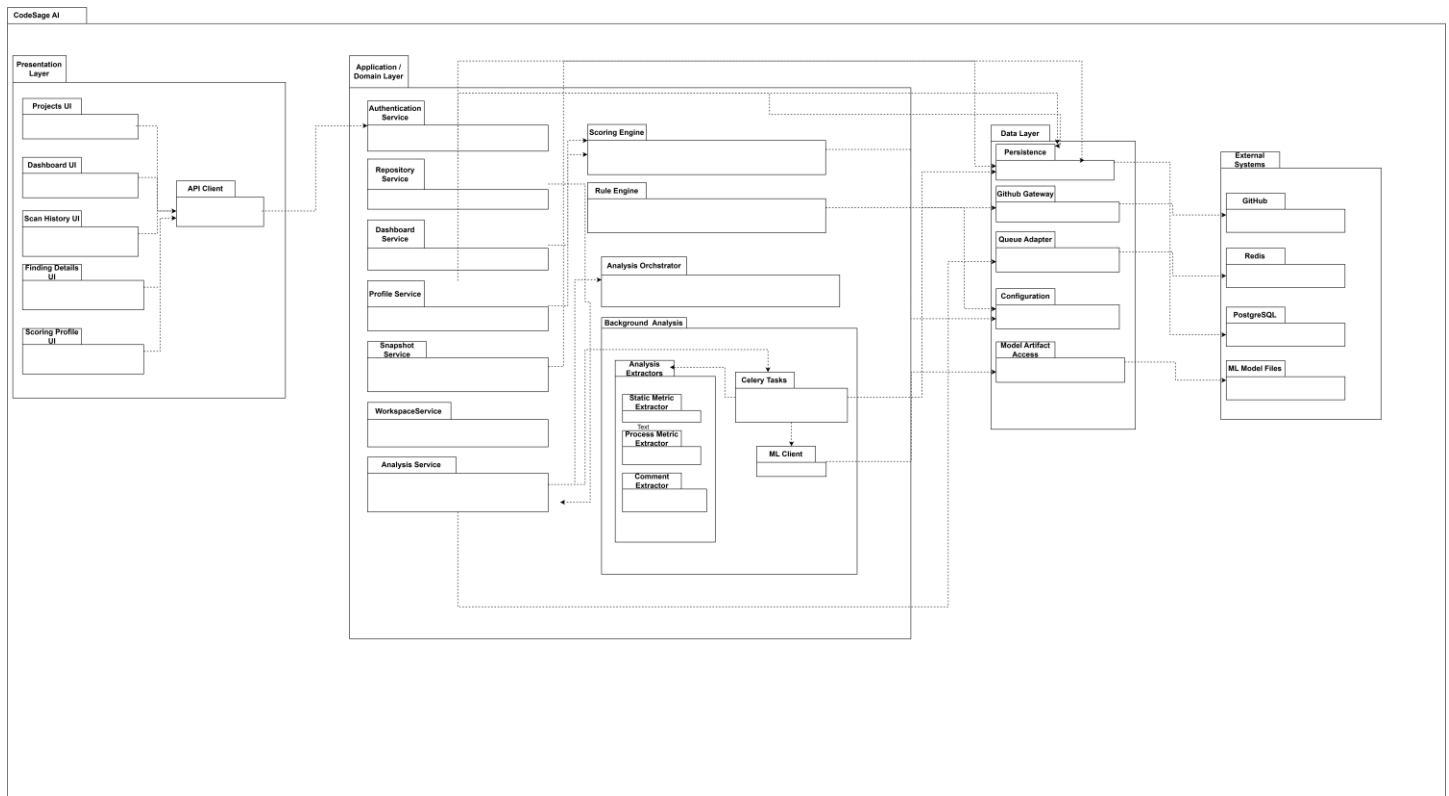


Figure 9. Package diagram of the backend application.

8.2.1 Presentation Layer

The Presentation Layer contains the Projects UI, Dashboard UI, Scan History UI, Finding Details UI, and Scoring Profile UI, which communicate with the backend through the API Client. It is responsible for user interaction and presentation while the database is forbidden.

8.2.2 Application Layer

The Application Layer contains the API routers and application services, including Authentication, Repository, Dashboard, Profile, Snapshot, Workspace, and Analysis Services, together with the Scoring Engine, Rule Engine, and Analysis Orchestrator. The background-analysis subsystem contains Celery Tasks, metric and comment extractors, and the ML Service. The scoring Engine is a pure Python function that takes stored findings, per-file facts, and the active profile and returns priorities, file debt, health, grade, and category breakdown, rather than computing these values in the database.

8.2.3 Data Layer

The Data Layer contains the Persistence, GitHub Gateway, Queue Adapter, Configuration, and Model Artifact Access packages. These components isolate database, GitHub, queue, configuration, and ML-model access from the application logic.

8.2.4 External Systems

The External Systems include GitHub, Redis, PostgreSQL, and ML model files, which provide external repository, queue, database, and model resources required by the system. Access to these resources is mediated through the respective adapters ensuring that external systems and databases are not accessed directly by the frontend.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

9. Data View

The diagram below represents the persistent data model of Code Sage AI. It is organized around four domains which are tenant and access management, repository analysis and snapshots, findings and prediction data and scoring and analysis configurations.

The workspace is the tenant boundary and it is associated with users through Membership. Repositories, branches, analysis attempts, snapshots, files, metrics and findings depict the persistent facts produced throughout the repository analysis lifecycle.

The supporting entities like MLModelVersion, AnalysisEngineVersion, RuleDefinition, DebtCategory, SATDMarkerPattern, Scoring Profile and ScoringPreset persist the configuration and provenance required to reproduce and interpret analysis results.

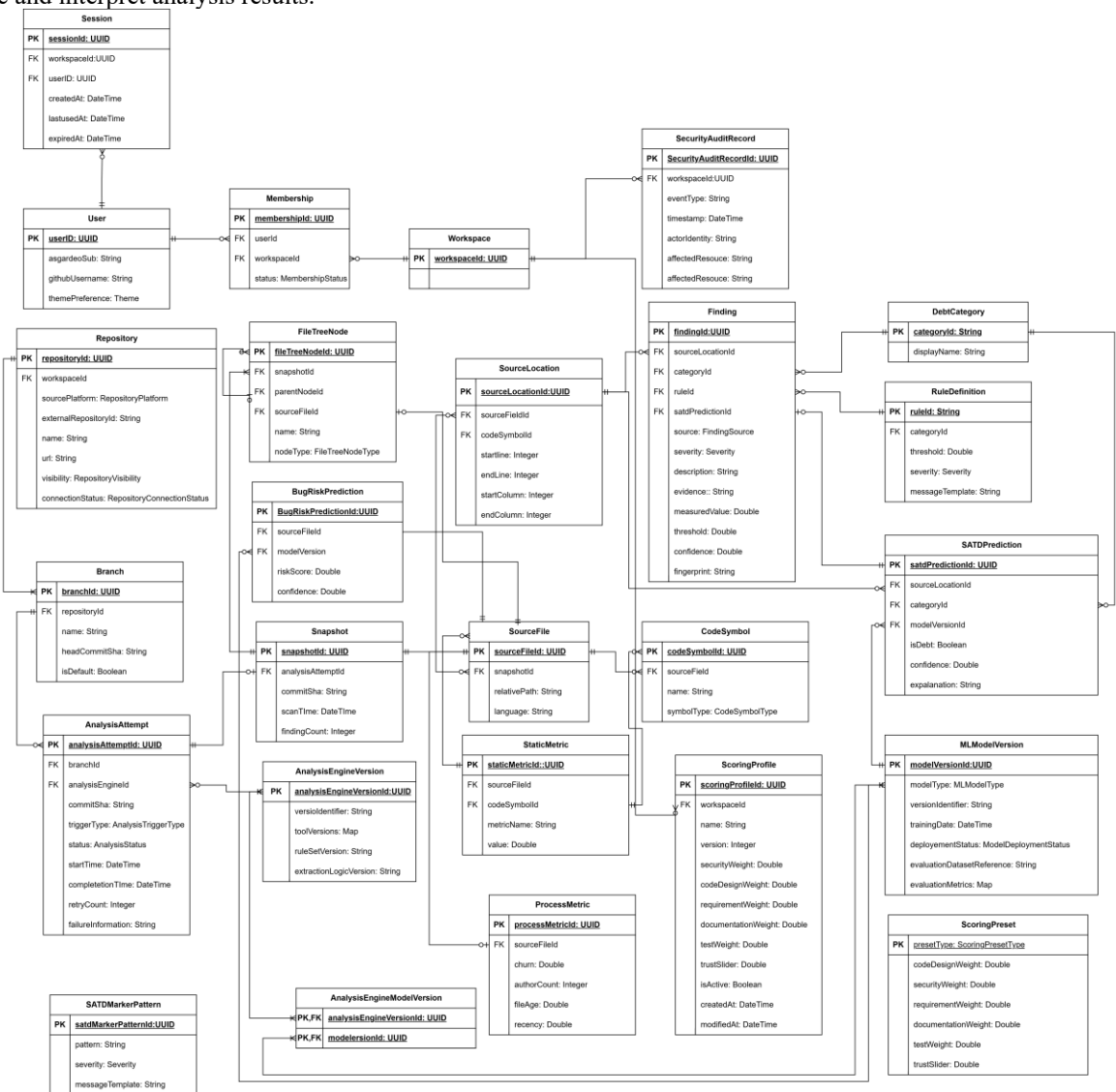


Figure 10. Multi-tenant data model.

The Data model can be viewed as four related groups.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Group	Entities	Role
Tenant and access data	User, Membership, Workspace, Session, SecurityAuditRecord	Establishing user-to-workspace ownership, tenant isolation and auditable activities
Repository and analysis data	Repository, Branch, AnalysisAttempt, Snapshot, SourceFile, FileTreeNode, CodeSymbol, SourceLocation, StaticMetric, ProcessMetric	Describing the repository revision being analyzed and the facts extracted from it.
Findings and machine-learning data	Finding, DebtCategory, BugRiskPrediction, SATDPrediciton	Capturing detected technical debt evidence and machine learning outputs linked with the analyzed code.
Configurations and provenance data	RuleDefinition, SATDDMarkerPattern, ScoringProfile, ScoringPreset, MLModelVersion, AnalysisEngineVersion, AnalysisEngineModelVersion	Recording the rules, scoring configurations, models and analysis engine versions used to produce each result.

Table 9-1. Persistent entities.

Entity	What it holds	Stored fact or derived?
Workspace	Tenant boundary for repositories, memberships, scoring profiles, and other workspace-owned data.	Stored fact
Membership	The relationship between users and workspaces. A user is identified by the subject identifier issued by the identity provider; the sign-in method used is an attribute, not the key. 'membership'allows the data model to support multiple users per workspace in later releases, although v1.0 permits only one active member.	Stored fact
Repository	Connected repository metadata including source platform, external repository identifier, name, URL, visibility, connection status, and owning workspace.	Stored fact
Branch	Repository branches, including branch name, current head commit SHA, and whether the branch is the default branch	Stored fact
AnalysisAttempt	Every attempted repository analysis, including branch, commit SHA, analysis-engine version, trigger type, execution status, timestamps, retry count, and failure information.	Stored fact
Snapshot	Immutable finalized result of a successfully completed analysis, including the associated analysis attempt, commit SHA, scan time, and finding count.	Stored fact

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Entity	What it holds	Stored fact or derived?
SourceFile, StaticMetric, ProcessMetric	Metadata describing analyzed files and the static and history-derived measurements extracted for the analyzed revision.	Stored fact
Finding	Detected technical-debt evidence including source, category, severity, location, reason/evidence, measured value, threshold, confidence where applicable, and fingerprint.	Stored fact
SATDPrediction, BugRiskPredicton	Outputs of the machine-learning models, including SATD prediction information and the per-file bug-risk score together with the model version that produced them.	Stored fact
ScoringProfile	Workspace-configurable weights, one per debt category, and the rule-versus-model trust setting used when deriving priorities and health scores. Five weights and one trust value, six numbers in all.	Stored configuration
RuleDefinition SatdMarkerPattern, DebtCategory	Rule, category, severity, threshold, marker, and message-template definitions used by the analysis pipeline.	reference data
MLModelVersion, AnalysisEngineVersion	Model and analysis-engine provenance required to reproduce and explain analysis results.	Reference data
FileTreeNode, CodeSymbol, SourceLocation	Structural metadata required to reconstruct the analyzed repository tree and locate findings within files and code symbols.	Stored fact

Scoring is performed in the application layer instead of calculating or storing as persistent database values. The database only stores analysis facts and scoring configuration and the profile-dependent outputs are derived using a deterministic Python function.

This keeps the scoring logic independently testable and allows thresholds and weights to change without requiring database schema or SQL-view changes. If read time scoring later becomes a measured performance bottleneck, PostgreSQL may be used to pre-aggregate the required inputs and the final profile dependent calculation remain in Python. However, this optimization is not a part of the v1.0 design.

Table 9-2. Columns and tables with a rule attached.

Column or table	Rule that applies to it	Requirement
FINDING.severity and FINDING.category	everity and category are assigned when the finding is created and stored as analysis facts. They are not changed when the scoring profile changes. Rule-engine findings use the fixed category and severity defined by their rule; SATD findings receive their category from the classifier and severity from the configured SATD marker rules.	FR-8.1, FR-9.2

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Column or table	Rule that applies to it	Requirement
FINDING.source	Identifies the detector that produced the finding. In v1.0, findings originate from either the rule engine or SATD detection. The bug-risk model produces a per-file risk score and does not create findings.	FR-8.2, FR-10
SCORING_PROFILE weights and trust_s	Category weights and the rule-versus-model trust value are configurable inputs to scoring. Changing them recalculates profile-dependent outputs from existing stored facts and must not trigger a new repository scan or modify a snapshot.	FR-20, FR-21, SP-7
SCORING_PROFILE.is_active	Marks the profile currently used when deriving priorities, health scores, grades, trends and category breakdowns for the workspace. A partial unique index on the workspace column, restricted to rows where this flag is set, makes a second active profile impossible to insert. Changing which profile is active changes derived values only; stored analysis facts are untouched.	FR-20, FR-21
SNAPSHOT (append-only)	Finalized analysis results are immutable and append-only. A successful analysis creates a new snapshot rather than updating an earlier one, so trend, history and delta are queries over existing rows in chronological order. A failed or cancelled attempt keeps its ANALYSIS_ATTEMPT row for diagnosis but creates no snapshot, which is what makes "only a completed scan can be read back" a property of the schema rather than a condition every query must remember.	FR-19, FR-21, REL-05, DBR-22, DBR-23

10. Size and Performance

Code Sage AI v1.0 is dimensioned to support at least 50 single-user workspaces, representing a baseline capacity of 50 registered users, while maintaining the specified response-time targets under normal operating conditions. The system shall support at least three repository-analysis requests concurrently. When the number of analysis requests exceeds the available processing capacity, additional requests are placed in the task queue without blocking interactive system functions such as authentication, navigation, access to analysis history, and access to previously completed results.

The architecture addresses these size and performance requirements in the following ways:

Non-blocking repository analysis:

Repository scans are executed by asynchronous worker processes rather than within the backend API request-response cycle. The API validates the request and places the analysis job in the Redis task queue, allowing the user interface

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

and other API operations to remain responsive while repository retrieval, metric extraction, technical-debt detection, and machine-learning inference are performed.

Efficient dashboard retrieval:

A dashboard request is handled using one database query followed by an in-memory scoring pass. The database stores findings and other facts produced by a scan, while profile-dependent values such as finding priority, file debt, health score, grade, delta, and category breakdown are calculated when the results are retrieved. Therefore, loading the dashboard or changing the active scoring profile does not require the repository to be scanned again. Because that derivation runs on every read, SRS PERF-11 sets a budget for it, and Section 11 records the measurement that confirms it.

Horizontal worker scaling:

The analysis-worker layer is the primary scaling point because repository scans consume considerably more processing, memory, and temporary storage than ordinary API requests. Additional worker containers can be deployed to increase concurrent analysis capacity without changing the frontend, API contract, or database schema. The SRS requires each component to be independently buildable and scalable.

Reduced dependence on GitHub REST quotas:

The repository-analysis pipeline retrieves the working tree and commit history through a read-only Git clone, which does not consume GitHub REST API quota. GitHub REST API calls are used only for repository metadata and use conditional requests to reduce rate-limit consumption.

Each worker requires at least 2 GB of temporary local disk space per concurrent scan for the repository clone and intermediate analysis files. This temporary storage is released when the analysis completes, fails, or is canceled.

Table 10-1. Dimensioning characteristics and performance targets.

Characteristic	Target	Source requirement
Registered users at baseline	Support at least 50 single-user workspaces, representing a baseline capacity of 50 registered users, while maintaining the specified response-time requirements.	PERF-06
Concurrent repository analysis	Support at least three repository-analysis requests concurrently. Requests exceeding the available capacity shall be queued without blocking interactive functionality.	PERF-07
Interaction feedback	Provide visible feedback within 0.1 seconds after receiving a direct user interaction.	PERF-01
Non-analysis interactions	Complete user interactions that do not involve repository retrieval or analysis within 1 second.	PERF-02
Scan enqueue	Place an initiated repository-analysis job in the task queue within 1 second.	PERF-03
Progress reporting	Provide progress and status information for an operation expected to take more than 10 seconds until it completes, fails, or is canceled.	PERF-04
Scan-progress polling	Poll the scan-status endpoint once every second while a scan is active. WebSockets and Server-Sent Events are not used in v1.0.	Communications Interface
Worker disk	Provide at least 2 GB of temporary local disk space for each concurrent repository	Hardware Interface

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

Characteristic	Target	Source requirement
	scan and release it when the scan ends.	
Dashboard read latency	Return the dashboard payload for one branch, including the derivation of its trend history, within 2 seconds at the 95th percentile under the baseline capacity.	PERF-11

The frontend obtains scan progress through asynchronous HTTP polling of the scan-status endpoint at a one-second interval. Polling stops when the scan reaches a completed, failed, or canceled state. This approach provides continuous progress information without adding the deployment complexity of WebSockets or Server-Sent Events in v1.0.

The deployment shall also monitor processor usage, memory usage, persistent storage, database connections, and analysis-worker queue utilization so that resource exhaustion and performance degradation can be detected. Under high analysis demand, queued scans may wait for worker capacity, but interactive parts of the application shall remain available.

11. Performance Measurements

The following values depend on the implemented system and deployment environment. They shall be measured during performance testing before the final submission rather than estimated during architectural design. The SAD template specifically requires these four measurements.

Measurement	Measured Value	Conditions to Record
Scan time per KLOC	[To be measured]	Repository language and size, commit-history size, worker CPU and memory, and model-loading state
Maximum concurrent scans per worker	[To be measured]	Worker CPU, memory, temporary disk, repository sizes, and acceptable performance degradation
P95 dashboard-read latency	[To be measured]	Number of files, findings and snapshots, concurrent-user load, and database configuration
Database size per snapshot	[To be measured]	Repository size, analyzed file count, finding count, stored evidence, and database indexes

12. Quality

This section explains how the software architecture contributes to all capabilities (other than functionality) of the system. The architecture designed to maintain a better reliability, security, maintainability, scalability and AI model quality.

12.1 Reliability

ID	Requirement	Architectural Mechanism
REL-01	Maintain high system availability	Fast API services and Celery workers are deployed separately using Docker containers, allowing individual services to restart independently.
REL-02	Prevent one repository analysis failure from affecting others	Each repository scan runs as an independent Celery task managed through Redis, isolating failures between analyses.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

REL-03	Preserve analysis history	PostgreSQL stores repository versions, analysis timestamps, statuses, and generated results for future reference.
REL-04	Handle temporary failures	Celery automatically retries failed tasks caused by temporary issues before reporting a final failure.
REL-05	Prevent incomplete results from replacing valid results	Analysis results are stored only after the complete analysis pipeline is successfully completed.
REL-06	Protect existing data during external service failures	Failures related to GitHub authentication or repository access stop the current scan without affecting previous successful analyses.
REL-10	Ensure consistent analysis results	Static analysis tools such as CK, Tree-sitter, and PyDriller generate consistent results for the same repository version.

12.2 Performance

ID	Requirement	Architectural Mechanism
PERF-01	Provide immediate feedback	The frontend provides loading indicators and status updates after user actions.
PERF-02	Provide fast dashboard access	Dashboard information is derived from the findings stored in PostgreSQL instead of running analysis repeatedly.
PERF-03	Quickly start repository scans	Scan requests are added to Redis queues immediately and processed asynchronously by workers.
PERF-04	Display analysis progress	Users can monitor the current analysis state such as Queued, Running, Completed, or Failed.
PERF-05	Maintain responsive user interaction	Heavy processing tasks are executed by Celery workers without blocking FastAPI requests.
PERF-07	Support multiple analyses simultaneously	Multiple worker instances can process different repository analyses concurrently.
PERF-09	Continue service operation during external failures	Previously generated reports remained available even when external services such as GitHub are temporarily unavailable.
PERF-11	Keep the derived dashboard fast	One indexed query per dashboard read followed by an in-memory scoring pass, with per-group sums available as an optimisation should the measurement in Section 11 show it is needed.

12.3 Security

ID	Requirement	Architectural Mechanism
SEC-01	Secure user authentication	Users authenticate through Asgardeo, which federates GitHub. The API completes the exchange and issues a server-side session; the browser holds only an httpOnly cookie.
SEC-04	Control repository access	v1.0 connects public repositories by pasting a URL and no GitHub App installation is used (SRS FR-3). Private-repository authorization is v2 (SRS SEC-04).
SEC-05	Apply minimum required permissions	The system uses read-only Git and REST access and never modifies repository resources (SRS SEC-05)

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

SEC-07	Protect communication	HTTPS/TLS encryption is used between clients and backend services.
SEC-08	Secure sensitive credentials	Tokens, API keys, and database credentials are stored securely using environment variables.
SEC-03 SEC-13	Ensure user data isolation	Repository data and analysis results are accessible only to authorized users.
SEC-11	Validate incoming requests	FastAPI validates API inputs before processing requests.
SEC-16	Prevent information leakage	Error messages are designed to avoid exposing sensitive system details.
SEC-10	Revoke access at sign-out	Sessions are rows in the database, so signing out deletes the row and the cookie stops being accepted on the next request. A self-contained token would stay valid until it expired.
SEC-17	Keep identity tokens away from the browser	The API is the Backend-for-Frontend: it performs the authorization-code exchange with PKCE and keeps every provider token in its own process. The browser receives an opaque session identifier and nothing else.
SEC-18	Authenticate every endpoint by default	Session resolution is a dependency of the same object that opens the database transaction, so a handler cannot run without an authenticated caller and a bound tenant. Only sign-in start, sign-in callback and the liveness probe are exempt, and the contract lists them.
SEC-19	Resist request forgery and unwanted origins	A signed single-use state value is verified on return from the identity provider; the session cookie is SameSite=Lax; and cross-origin access is limited to an explicit list of origins rather than a wildcard.
SEC-20	Harden the responses themselves	Strict-Transport-Security, a Content-Security-Policy, X-Content-Type-Options, a frame-ancestors restriction and a Referrer-Policy are set on responses by middleware, so the policy is applied in one place.

12.4 Privacy

ID	Requirement	Architectural Mechanism
PRI-01	Protect repository confidentiality	Repository details and analysis results are available only to authenticated users.
PRI-02	Secure credential management	No user credential is stored at all: sign-in happens at the identity provider and v1.0 clones public repositories anonymously. Service credentials are held only by backend containers, supplied as environment variables.
PRI-03	Minimize collected data	The system processes only the information required for technical debt analysis.
PRI-04	Protect data transmission	HTTPS/TLS ensures secure communication between users and system services.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

12.5 Usability

ID	Requirement	Architectural Mechanism
U-01	Provide a simple workflow	Users can connect repositories, start analysis, and view results through a clear process.
U-02	Improve result understanding	Findings are presented using severity levels, health scores, and explanations.
U-03	Support visual analysis	Charts and repository views help users identify technical debt areas.
U-04	Maintain interface consistency	Reusable frontend components provide a consistent user experience.
U-05	Show analysis progress	Users can view the current progress of long-running operations.
U-06	Support recovery from failures	Previous successful reports remain accessible even if a new scan fails.

12.6 Maintainability

ID	Requirement	Architectural Mechanism
MAINT-01	Support modular development	System components are separated into independent modules.
MAINT-02	Reduce system coupling	Presentation, business logic, and data management layers are separated.
MAINT-03	Allow future extensions	New analysis tools, programming languages, and AI models can be added with minimal changes.
MAINT-04	Support configurable scoring	Technical debt prioritization rules can be modified through configuration instead of code changes.
MAINT-05	Allow independent AI model updates	Machine learning models are maintained separately as versioned artifacts.

12.7 Supportability

ID	Requirement	Architectural Mechanism
SUP-01	Support troubleshooting	System events, scan status, and execution details are recorded through centralized logging.
SUP-02	Maintain communication consistency	Shared API models ensure consistent data exchange between frontend and backend.
SUP-03	Ensure deployment consistency	Docker containers provide the same environment across development and production.
SUP-04	Enable independent testing	Individual components can be tested separately.
SUP-05	Support automated deployment	The modular structure allows integration with CI/CD pipelines.

12.8 Portability

ID	Requirement	Architectural Mechanism
PORT-01	Support different deployment environments	Docker containers allow deployment across different platforms.

Code Sage AI	Version: 1.1
Software Architecture Document	Date: 15/08/2026
CS3203-G16-SAD-v1.1	

PORT-02	Support additional languages	New parsers and analysis rules can be integrated for other programming languages.
PORT-03	Provide platform-independent access	The web-based application can be accessed through modern browsers.

12.9 Scalability

ID	Requirement	Architectural Mechanism
SCALE-01	Scale system components independently	Frontend, backend, and worker services can be scaled separately using containers.
SCALE-02	Handle heavy processing efficiently	Celery workers execute analysis tasks in the background.
SCALE-03	Manage increasing workloads	Redis queues organize and distribute analysis requests efficiently.

12.10 AI Model Quality

ID	Requirement	Architectural Mechanism
AI-01	Improve SATD detection accuracy	The SATD classifier is trained using labelled datasets and evaluated using metrics such as Precision, Recall, and F1-score before deployment.
AI-02	Provide reliable bug prediction	The bug-proneness model is trained using software metrics and validated before integration.
AI-03	Maintain reproducible predictions	The system records the model version used for each prediction.
AI-04	Support model replacement	Machine learning models are stored separately and can be updated without changing application logic.
AI-05	Separate training and prediction processes	Model training is performed offline, while the deployed application only performs inference to maintain stable performance.